Implementación de un SOC Nivel 1 para ERP Pyme S.A.S.

Caso C21 · Informe técnico del parcial de segundo corte Ética del Hacking / Ciberseguridad Defensiva

Campo	Dato
Docente	Julián Barney Jaimes Rincón
Estudiante(s)	Brayan Javier Becerra Sandoval; Christian Julian Peña Mantilla
Programa	Ingenieria de Sistemas
Caso elegido	C21 — ERP Pyme S.A.S. (implementación de ERP de código abierto)
Presupuesto del caso	Bajo: CAPEX ≤ COP 20 millones; OPEX ≤ COP 1,5 millones por mes
Fecha de entrega	22/10/2026
Archivo de entrega	Parcial_SOC_N1_C21_[Apellido].pdf
Repositorio (privado)	soc-n1-c21-[apellido]

Todas las empresas, personas y datos de este documento son ficticios. Cualquier parecido con una organización real es coincidencia.

Historial de versiones del informe

Versión	Fecha	Autor	Cambio
0.1	19/10/2026	Brayan Javier Becerra Sandoval	Revisión del informe; integración de las dos capturas de Wazuh, ajustes de fase 2 y presupuesto hipotético de fase 7
1.0	19/10/2026	Brayan Javier Becerra Sandoval	Versión final académica; diferencia explícita entre evidencia disponible y componentes hipotéticos
1.1	21/10/2026	Brayan Javier Becerra Sandoval; Christian Julian Peña Mantilla	Integración de las capturas de Kaspersky y de la lista de VM; fases 2 y 3 actualizadas; firmas en el Anexo I

Contenido

1. Resumen ejecutivo 4

2. Caso y alcance 4

2.1 Descripción de la empresa 4
2.2 Justificación de la elección del caso 5
2.3 Supuestos declarados 5
2.4 Marco ético y legal 6
2.5 Carta de autorización y reglas de compromiso 6
2.6 Alcance del proyecto 6
2.7 Inventario de activos (resumen) 7
2.8 Matriz de riesgos (resumen) 7
2.9 Escenarios de alerta del caso 8

3. Arquitectura 8

3.1 Diagrama de red 8
3.2 Segmentación en VLAN y reglas entre zonas 10
3.3 Flujo de logs y puertos 11
3.4 Dimensionamiento de la plataforma para 20 agentes 12
3.5 Plan de despliegue de agentes al resto de la organización 13
3.6 Servicios transversales y decisión de arquitectura del SIEM 13

4. SIEM Wazuh 14

4.1 Selección y versión 14
4.2 Instalación del servidor (todo en uno) 14
4.3 Grupos y despliegue de agentes 16
4.4 Monitoreo de integridad de archivos (FIM) 16
4.5 Evaluación de configuración (SCA) 17
4.6 Detección de vulnerabilidades 17
4.7 Reglas y decoders personalizados 17
4.8 Respuesta activa (active response) 18
4.9 Tableros de control 19
4.10 Pruebas controladas y resultados 19

5. EDR/XDR Kaspersky 20

5.1 Selección y justificación de la edición 20
5.2 Instalación de la consola de administración 21
5.3 Despliegue de agentes 21
5.4 Políticas aplicadas 22
5.5 Tareas programadas 23
5.6 Exclusiones y su justificación 24
5.7 Integración de eventos con Wazuh (Syslog/CEF) 24
5.8 Prueba de detección con el archivo EICAR 25

6. GLPI en la nube 26

6.1 Diseño de la solución 26
6.2 Endurecimiento del servidor en la nube 27
6.3 Instalación web y HTTPS 28
6.4 Configuración para la puesta en marcha 29
6.5 Respaldos y prueba de restauración 35
6.6 Lista de verificación de GLPI 36

7. Firewall de nueva generación (NGFW) 36

7.1 Requisitos técnicos 36
7.2 Proceso de cotización 37
7.3 Cuadro comparativo y TCO a 3 años 37
7.4 Matriz de decisión ponderada 39
7.5 Selección y justificación 39

8. Procesos del SOC N1 40

8.1 Modelo operativo y roles 40

8.2 Matriz de severidad 40
8.3 Flujo de triage 41
8.4 Acciones permitidas y prohibidas para el N1 41
8.5 Plantilla de escalamiento a N2 41
8.6 Playbooks adaptados al caso 42
8.7 Turnos y guardias 43
8.8 SLA del SOC 43
8.9 Indicadores (KPIs) 43
8.10 Tickets gestionados en GLPI 44
8.11 Informe de incidente 47

9. Presupuesto y cronograma 47
9.1 Supuestos de costos 47
9.2 Presupuesto detallado 48
9.3 Indicadores financieros y cumplimiento del tope 50
9.4 Escenario básico y recomendado 51
9.5 Cronograma de implementación para la empresa (8 semanas) 52
9.6 Plan de trabajo del parcial (2 semanas) 52
9.7 Matriz RACI 53

10. Conclusiones 54
10.1 Resultados 54
10.2 Limitaciones 54
10.3 Riesgos residuales 54
10.4 Trabajo futuro 55

Referencias 56

Anexos 57
Anexo A — Inventario de activos (20 equipos) 57
Anexo B — Matriz de riesgos 58
Anexo C — Plantilla de ticket de seguridad (GLPI) 59
Anexo D — Informe de incidente 60
Anexo E — Correo de solicitud de cotización y cuadro consolidado 62
Anexo F — Playbooks del SOC N1 adaptados al caso C21 64
Anexo G — Lista de verificación de entrega 69
Anexo H — Carta de autorización y reglas de compromiso 70
Anexo I — Declaración de uso de inteligencia artificial 71

Lista de figuras

Figura 1. Arquitectura de red del SOC N1 – Caso C21 (ERP Pyme S.A.S.) 8
Figura 2. Flujo de logs y puertos – Caso C21 10
Figura 3. Finalización de la instalación de Wazuh en SRV-C21-WAZUH (credenciales ocultas) 13
Figura 4. Dashboard de Wazuh; agentes sin resultados visibles 14

1. Resumen ejecutivo

El caso. ERP Pyme S.A.S. es una pyme de TI ficticia que implementa ERP de código abierto para otras empresas. Tiene 10 empleados y 20 equipos de cómputo, trabaja de forma híbrida y su madurez de seguridad es baja: no cuenta con SIEM, EDR centralizado ni sistema de tickets de seguridad. Su riesgo principal es que mantiene servidores de demostración accesibles desde Internet, a veces sin parchear, y que en los entornos de prueba pueden terminar datos reales de sus clientes (contables, de nómina y de terceros).

Estado real y alcance supuesto. La evidencia adjunta confirma que el instalador de Wazuh terminó y que se abrió su dashboard. La captura del dashboard muestra 90 alertas de severidad media y 16 de severidad baja en las últimas 24 horas, pero el resumen de agentes aparece como “No results”; por tanto, estas imágenes no demuestran agentes conectados ni validan las demás funciones. Para mantener la integridad académica, la arquitectura completa, Kaspersky, GLPI, las reglas avanzadas, los tickets, las cotizaciones y los costos se presentan como diseño hipotético/propuesto, salvo cuando exista una evidencia original específica.

Actualización de evidencia. Con las capturas del 21/10/2026 se evidencia además que Kaspersky Endpoint Security para Windows 14.1.0.423 está instalado en la VM WIN10-KASPERSKY-01 y administrado desde una consola en la nube, con el agente conectado y sin amenazas activas (capítulo 5). Siguen sin evidencia los agentes de Wazuh, la prueba con EICAR y el envío de eventos de Kaspersky a Wazuh.

Resultados verificables con las capturas aportadas: la instalación de Wazuh finalizó y el dashboard web abrió correctamente. No se afirma que existan agentes activos, ni que FIM, SCA, vulnerabilidades, reglas personalizadas o respuesta activa hayan sido probadas; quedan como pruebas propuestas para un despliegue hipotético. Las cifras de alertas visibles corresponden al dashboard en la captura y no se atribuyen a un escenario de ataque específico.

Estimación académica hipotética. El escenario recomendado usa valores de referencia ilustrativos (no cotizaciones verificadas) de CAPEX COP 14.300.000, OPEX mensual COP 1.348.000 y TCO a 3 años COP 62.828.000. Estos valores solo permiten comparar escenarios frente a los topes supuestos del caso C21; deben reemplazarse por cotizaciones reales y tarifas vigentes antes de cualquier decisión de compra.

Declaración de integridad. El documento distingue evidencia observada, diseño propuesto y simulación académica. No representa una implementación real en una empresa ni se afirma que herramientas no evidenciadas estén desplegadas. El uso de IA se declara en el Anexo I.

2. Caso y alcance

2.1 Descripción de la empresa

ERP Pyme S.A.S. implementa y da soporte a ERP de código abierto para empresas clientes. Su operación se apoya en consultores funcionales (que trabajan en oficina o en las instalaciones del cliente), dos personas de gerencia, desarrolladores y cuatro servidores Ubuntu Server. El negocio depende de la confianza de los clientes: una fuga de datos contables o de nómina de un cliente tendría impacto legal, contractual y reputacional.

Característica	Valor del caso C21

Característica	Valor del caso C21
Giro	Implementación de ERP de código abierto
Empleados / equipos	10 empleados / 20 equipos de cómputo
Modalidad	Híbrida
Madurez de seguridad	Baja
Red	Router/NGFW, switch de 16 puertos y 2 puntos de acceso (se cuentan aparte de los 20 equipos). 4 VLAN: Oficina, Servidores, Seguridad y Gestión
Servicios expuestos	Servidores de demostración accesibles por Internet para clientes; VPN para soporte
Activos críticos	Servidores de demostración y staging; respaldos con datos de clientes
Datos sensibles	Datos contables, de nómina y de terceros de las empresas clientes
Cumplimiento	Ley 1581; contratos de confidencialidad; buenas prácticas de enmascaramiento de datos en pruebas
Presupuesto	Bajo: CAPEX ≤ COP 20 M; OPEX ≤ COP 1,5 M/mes

2.2 Justificación de la elección del caso

Se eligió el caso C21 porque sus tres escenarios de alerta (vulnerabilidad crítica, fuerza bruta SSH y cambio en archivos críticos) se originan en Wazuh y pueden reproducirse de forma controlada en máquinas virtuales propias, sin requerir equipos macOS ni Windows Server en el laboratorio. Esto permite concentrar el esfuerzo en la calidad de la implementación, la documentación y el ciclo completo de atención de alertas. Esta decisión no altera los datos del caso.

2.3 Supuestos declarados

Los datos del caso (cantidad de empleados, equipos y sistemas operativos) no se modificaron. Se añadieron los siguientes supuestos razonables:

N.º	Supuesto	Justificación
S-01	El ERP de demostración es Odoo Community, con configuración en /etc/odoo/odoo.conf	El caso solo dice «ERP de código abierto»; se necesita una ruta concreta para el FIM
S-02	Plan de direccionamiento: VLAN 10 Oficina 10.10.10.0/24; VLAN 20 Servidores 10.10.20.0/24; VLAN 90 Seguridad 10.10.90.0/24; VLAN 99 Gestión 10.10.99.0/24; laboratorio host-only 192.168.56.0/24	Rangos privados ficticios; no se usan IP públicas reales
S-03	Dominio de ejemplo: erppyme.example (dominio reservado)	Regla de datos ficticios de la guía
S-04	Horario laboral: lunes a viernes, 7:00–19:00 (America/Bogota)	Base de la regla de inicio de sesión fuera de horario
S-05	Modelo de SOC híbrido: N1 interno en horario laboral; N2 tercerizado por ticket	Coherente con presupuesto bajo y con la sección 4.5 de la guía
S-06	Los 10 usuarios, nombres y correos son ficticios	Ley 1581 y reglas del parcial
S-07	Proveedor cloud genérico en región de Colombia o región cercana; instancia y costos solo de referencia, sin servicio contratado.	—

2.4 Marco ético y legal

Todo el trabajo es defensivo y se realiza sobre activos propios, con autorización escrita. Se aplican estos principios y normas:

- **Ley 1273 de 2009:** tipifica el acceso abusivo a sistemas informáticos (art. 269A), la interceptación de datos (269C), el daño informático (269D) y el software malicioso (269E), entre otros. Es el límite legal de cualquier prueba y justifica la carta de autorización y el laboratorio aislado.
- **Ley 1581 de 2012 y Decreto 1074 de 2015:** régimen de protección de datos personales. Los logs del SOC contienen datos personales (usuarios, IP, correos), por lo que se aplican los principios de finalidad, seguridad y confidencialidad; la empresa actúa como responsable o encargada del tratamiento según el cliente.
- **ISO/IEC 27001:2022 y NIST CSF 2.0:** referencias para justificar controles (A.5.9, A.8.7, A.8.8, A.8.15, A.8.16, A.5.24–5.28; funciones GV, ID, PR, DE, RS).
- **Principios éticos:** autorización previa, proporcionalidad y mínimo privilegio, no maleficencia, confidencialidad, transparencia e integridad, y divulgación responsable.

Fase	ISO/IEC 27001:2022 (Anexo A)	NIST CSF 2.0
0 Alcance y ética	A.5.9 Inventario de activos; cláusulas 4 y 6	GV, ID.AM, ID.RA
1 Arquitectura	A.8.15; A.8.20–8.22	PR.IR, DE.CM
2 Wazuh	A.8.15; A.8.16; A.8.8; A.8.9	DE.CM, DE.AE, ID.RA
3 Kaspersky	A.8.7; A.8.16	DE.CM, PR.PS, RS.MI
4 GLPI	A.5.9; A.5.24–5.28	ID.AM, RS.MA, RS.CO
5 NGFW	A.8.20; A.8.22; A.5.19–5.23	PR.IR, GV.SC
6 Procesos SOC N1	A.5.24–5.28; A.6.8	DE.AE, RS.MA, RS.AN, RS.CO
7 Presupuesto y plan	Cláusulas 6.1 y 7	GV.RR, GV.RM
8 Documentación	Cláusula 7.5	GV.PO

2.5 Carta de autorización y reglas de compromiso

Para este ejercicio académico ficticio, la carta del Anexo H se incluye como modelo sin efecto jurídico y sin firmas reales. No se realizaron actividades sobre una empresa real ni sobre sistemas de terceros. En un proyecto real, la autorización escrita tendría que estar aprobada antes de ejecutar cualquier prueba.

> ***[CAPTURA F00-01 · F00_carta_autorizacion_firmada.png]*** *Pega aquí la carta del Anexo H firmada (o validada por el docente). Debe verse la ventana de actividades (fechas de inicio y fin), el listado de activos incluidos y las firmas. No incluyas datos personales reales.*

2.6 Alcance del proyecto

Incluye	No incluye
Diseño completo del SOC N1 para el caso C21	Compra o instalación física del NGFW (solo se cotiza)
Instalación real de Wazuh, Kaspersky y GLPI en laboratorio	Respuesta a incidentes avanzada y análisis forense (N2/N3)

Incluye	No incluye
Agentes en un conjunto representativo de equipos	Pruebas ofensivas contra activos que no sean propios
Cotización de NGFW con proveedores reales	Integración automática Wazuh → GLPI (mejora futura; los tickets se crean manualmente)
Procesos, playbooks, SLA, KPIs y presupuesto	Uso de datos reales de personas o empresas

Laboratorio mínimo representativo. Red virtual aislada (host-only o NAT interna) con: SRV-C21-WAZUH (Ubuntu Server LTS, 4 vCPU, 8 GB RAM, 50 GB), PC-C21-WIN01 (Windows 11, agentes Wazuh y Kaspersky), SRV-C21-STG (Ubuntu Server que representa al servidor de staging, agente Wazuh), una VM Ubuntu auxiliar para generar intentos fallidos de SSH, la consola Kaspersky (No ejecutado; supuesto académico hipotético) y la instancia de GLPI en la nube. El despliegue masivo al resto de la organización se documenta en el capítulo 9.

2.7 Inventario de activos (resumen)

El inventario completo de 20 equipos, con hostname, VLAN, valoración C/I/D, criticidad y agentes, está en el **Anexo A**.

Tipo	Cantidad	Sistema operativo	Función
Estación	8	Windows 11 Pro	Consultores funcionales
Portátil	4	Windows 11	Consultores en cliente
Portátil	2	macOS	Gerencia
Estación	2	Ubuntu Desktop	Desarrollo
Servidor	4	Ubuntu Server	ERP de demostración, base de datos, staging y respaldo
Total	**20**		

2.8 Matriz de riesgos (resumen)

La matriz completa (13 riesgos, con probabilidad, impacto, nivel, control del SOC, responsable y fase) está en el **Anexo B**. Escalas: P e I de 1 a 5; nivel = P × I (1–4 Bajo, 5–9 Medio, 10–16 Alto, 17–25 Crítico). Los riesgos más relevantes son:

ID	Riesgo	Nivel	Control del SOC
R-02	Servidores de demostración sin parchear con CVE críticos	20 (Crítico)	Detección de vulnerabilidades de Wazuh y PB-09
R-01	Fuerza bruta SSH contra servidores expuestos	16 (Alto)	Reglas de autenticación, active response y PB-01
R-03	Datos reales de clientes en entornos de prueba	15 (Alto)	Política de enmascaramiento, FIM y revisión periódica
R-04	Alteración no autorizada de la configuración del ERP	12 (Alto)	FIM sobre /etc/odoo y PB-03

2.9 Escenarios de alerta del caso

N.º	Escenario	Fuente	Descripción	Playbook
1	Vulnerabilidad crítica	Wazuh	CVE crítico en la base de datos o en las librerías del servidor de demostración	PB-09
2	Fuerza bruta SSH	Wazuh	Múltiples fallos de autenticación SSH contra el servidor de staging	PB-01
3	Cambio en archivos críticos (FIM)	Wazuh	Se altera el archivo de configuración del ERP	PB-03

Además, para cubrir los seis tipos mínimos de ticket se gestionan alertas de malware (EICAR en Kaspersky, PB-02), inicio de sesión fuera de horario (PB-04) y uso de USB (PB-05).

3. Arquitectura

3.1 Diagrama de red

La red de la empresa se compone de un router/NGFW perimetral, un switch administrable de 16 puertos (troncal 802.1Q hacia el NGFW) y dos puntos de acceso. Se segmenta en cuatro VLAN: Oficina (10), Servidores (20), Seguridad (90) y Gestión (99), con direccionamiento privado de ejemplo 10.10.x.0/24. Todo el tráfico entre VLAN pasa por el NGFW, que aplica las reglas de la sección 3.2. El SIEM Wazuh (SRV-C21-SOC) y la consola Kaspersky (KSC) se ubican en la VLAN 90, con acceso restringido a los analistas N1. **Supuesto S-08:** el SIEM y la consola Kaspersky corren en VM adicionales (sobre hardware existente o en la nube), costeadas en el capítulo 9; no se cuentan dentro de los 20 equipos de cómputo del caso, pero sí son activos monitoreados. La Figura 1 muestra la arquitectura completa, incluidos los consultores remotos por VPN, el único servicio de demostración publicado (HTTPS 443 hacia SRV-C21-DEMO) y la instancia de GLPI en la nube.

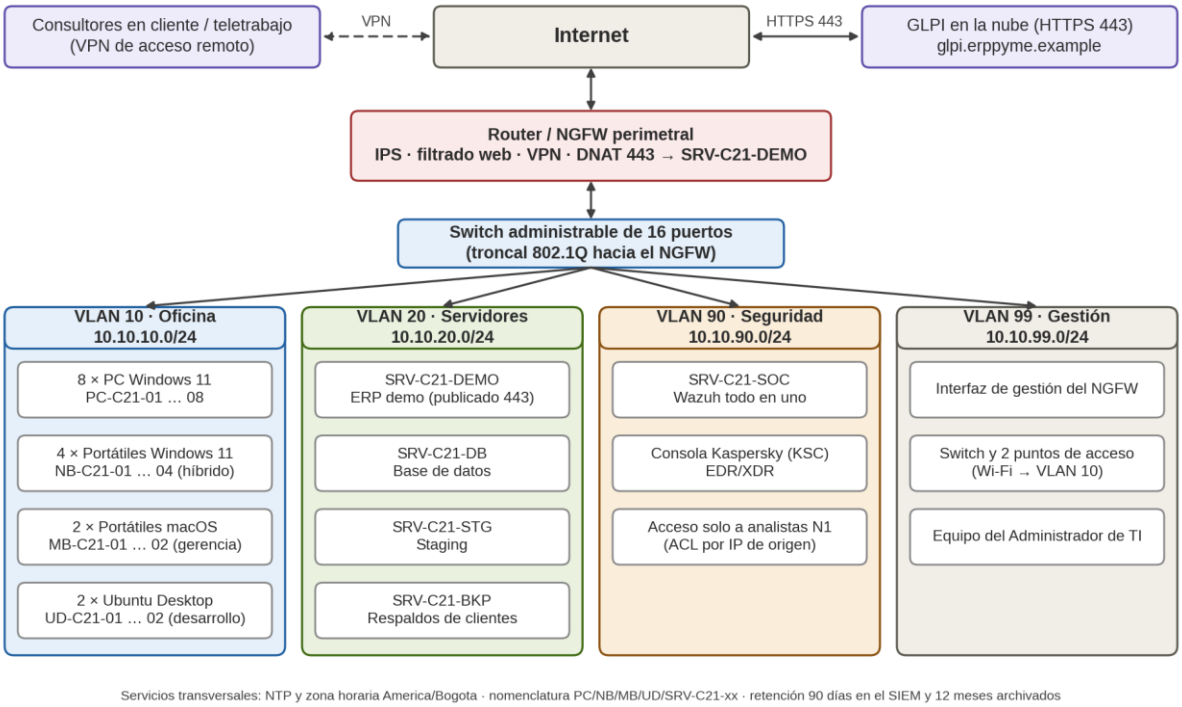
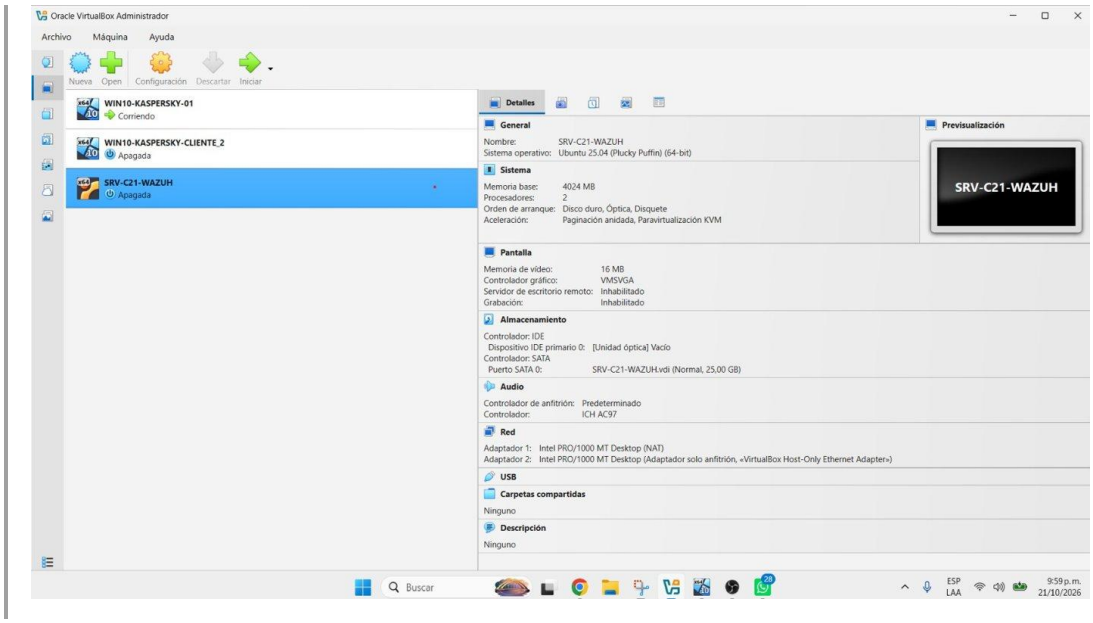


Figura 1. Arquitectura de red del SOC N1 – Caso C21 (ERP Pyme S.A.S.)

Nomenclatura. La figura usa los nombres del diseño de producción. En el laboratorio la VM del SIEM equivalente a SRV-C21-SOC se llama SRV-C21-WAZUH, y solo se instancian PC-C21-WIN01 y SRV-C21-STG junto con la VM auxiliar y la consola Kaspersky (sección 2.6); el resto de equipos se cubre con el plan de despliegue de la sección 3.5.



Captura F01-02. Oracle VirtualBox: VM del laboratorio WIN10-KASPERSKY-01 (en ejecución), WIN10-KASPERSKY-CLIENTE_2 (apagada) y SRV-C21-WAZUH (Ubuntu 25.04, 4 GB de RAM, 25 GB de disco; adaptadores NAT y solo anfitrión). Hora del equipo: 9:59 p. m., 21/10/2026.

3.2 Segmentación en VLAN y reglas entre zonas

VLAN	Nombre	Red	Equipos	Justificación
10	Oficina	10.10.10.0/24	8 estaciones y 4 portátiles Win11, 2 portátiles macOS y 2 Ubuntu Desktop (16 equipos); Wi-Fi de los puntos de acceso	Usuarios finales; mayor exposición a phishing y malware; salida a Internet filtrada
20	Servidores	10.10.20.0/24	4 Ubuntu Server: SRV-C21-DEMO, DB, STG y BKP	Activos críticos con datos de clientes; acceso administrativo solo desde la VLAN 99
90	Seguridad	10.10.90.0/24	SRV-C21-SOC (Wazuh) y consola Kaspersky (KSC)	Recibe eventos de agentes, NGFW y EDR; acceso solo de analistas N1 (ACL por IP de origen)
99	Gestión	10.10.99.0/24	Interfaz de gestión del NGFW, switch, 2 puntos de acceso y equipo del Administrador de TI	Administración de la infraestructura de red, separada del tráfico de usuarios

La segmentación responde a ISO/IEC 27001 A.8.22 (segregación de redes) y limita el movimiento lateral desde la oficina hacia los servidores de demostración; además, aísla las herramientas del SOC (VLAN 90) y la administración de red (VLAN 99). El caso no contempla red de invitados, por lo que no se define la VLAN 30 de la guía de referencia.

Origen	Destino	Servicio	Acción	Motivo
Internet	SRV-C21-DEMO	HTTPS 443 (DNAT)	Permitir	Demostraciones a clientes; solo ese servicio y ese servidor
Internet	VLAN 20, 90 y 99	Cualquier otro servicio	Denegar	El acceso administrativo solo por VPN
VPN de soporte	VLAN 20	SSH 22 con llave	Permitir (solo Admin. de TI)	Soporte remoto
VLAN 10	VLAN 20	HTTPS al ERP	Permitir	Uso del ERP
VLAN 10	VLAN 20	SSH 22	Denegar	La administración se hace solo desde la VLAN 99
VLAN 99 (Admin. de TI)	VLAN 20 y 90	SSH 22 con llave	Permitir	Mínimo privilegio; administración de servidores y del SIEM
VLAN 20	VLAN 10	Iniciado desde servidores	Denegar (solo tráfico de retorno)	Evita movimiento lateral
VLAN 10 y 20	VLAN 90 (SIEM)	1514/TCP y 1515/TCP	Permitir	Agentes Wazuh
VLAN 10 y 20	VLAN 90 (KSC)	13000/TCP (verificar)	Permitir	Network Agent de Kaspersky
Equipos autorizados de analistas N1 (VLAN 10)	VLAN 90	443/TCP	Permitir (ACL por IP de origen)	Dashboard de Wazuh y consola de Kaspersky
NGFW (VLAN 99)	VLAN 90 (SIEM)	514 UDP/TCP (syslog)	Permitir	Logs de firewall, IPS y VPN
SRV-C21-DEMO y SRV-C21-DB	SRV-C21-BKP	Sincronización programada	Permitir	Copias de seguridad

3.3 Flujo de logs y puertos

Origen	Destino	Puerto / protocolo	Contenido	Observaciones
Agentes Wazuh (20)	Wazuh server	1514/TCP	Eventos, FIM, SCA, inventario	Cifrado con clave por agente
Agentes Wazuh	Wazuh server	1515/TCP	Registro (enrolamiento) del agente	Solo durante el alta
Analistas N1 (equipos autorizados de VLAN 10)	Wazuh dashboard	443/TCP	Consola web	Restringido por ACL a la IP de origen
Wazuh dashboard	Wazuh API	55000/TCP	Administración	Solo local
Wazuh server	Wazuh indexer	9200/TCP	Alertas	Interno (instalación todo en uno); solo local
NGFW	Wazuh server	514/UDP o TCP (syslog)	Logs de firewall, IPS y VPN	Limitar por IP de origen
Consola Kaspersky (KSC)	Wazuh server	514/UDP o TCP (syslog, formato CEF)	Detecciones y eventos del EDR	Ver capítulo 5
Agentes Kaspersky (Network Agent)	Consola Kaspersky (KSC)	13000/TCP (y 14000/TCP según la edición)	Telemetría y políticas	Verificar en la documentación oficial de la edición elegida
GLPI Agent (endpoints)	GLPI en la nube	443/TCP (HTTPS)	Inventario	Certificado válido
Analistas N1	GLPI en la nube	443/TCP (HTTPS)	Gestión de tickets	Acceso por perfiles
GLPI	Servidor de correo	587/TCP (SMTP con STARTTLS)	Notificaciones	Cuenta creada para el ejercicio
Administradores	GLPI (SSH)	22/TCP	Administración	Solo desde IP autorizada y con llave

Los puertos de Wazuh corresponden a la documentación oficial; los de Kaspersky y del NGFW deben verificarse con la edición y el modelo elegidos.

La Figura 2 resume los flujos de la tabla anterior: el trazo continuo corresponde al tráfico de los agentes o de las consolas y el punteado a los logs enviados por syslog. Todos los eventos se registran con hora NTP en la zona America/Bogota para poder correlacionarlos.

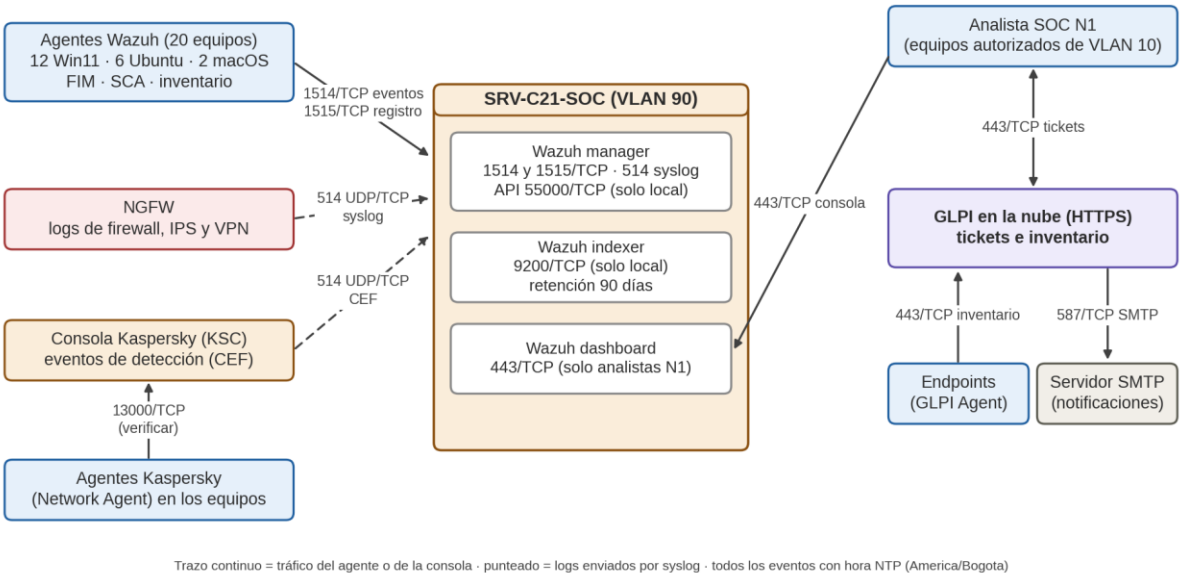


Figura 2. Flujo de logs y puertos – Caso C21

3.4 Dimensionamiento de la plataforma para 20 agentes

Parámetro	Valor	Fuente / justificación
Agentes Wazuh	20 (más 2 fuentes syslog: NGFW y consola Kaspersky)	Inventario del caso
Arquitectura	Todo en uno (indexer, server y dashboard en una VM)	Adecuada para 1–25 agentes
CPU / RAM	4 vCPU / 8 GB	Requisitos de referencia de Wazuh para 1–25 agentes
Disco	50 GB mínimo para laboratorio; 100 GB recomendado para el diseño por retención de 90 días y margen de crecimiento. No se midió el crecimiento real del índice.	Retención de 90 días de alertas
Eventos por segundo (EPS)	No medido en las capturas. Para dimensionamiento se usa una proyección de planificación de 5–10 EPS promedio para el laboratorio y se recalibra con métricas reales antes de producción.	Medición propia
Retención en caliente	90 días de alertas	Política de ciclo de vida de índices
Retención de archivo	Exportación mensual comprimida con retención de 12 meses propuesta; no configurada ni probada.	Minimización de datos (Ley 1581)

Parámetro	Valor	Fuente / justificación
Respaldo del SIEM	Instantánea de la VM y copia de /var/ossec/etc y reglas	Recuperación ante fallos
Margen de crecimiento	25–30 % (hasta unos 26 agentes y nuevas fuentes syslog)	Guía del parcial, Fase 1. Con 26 agentes la referencia de Wazuh sube a 8 vCPU y 100 GB: se parte con 100 GB de disco y se revisa la CPU al superar 25 agentes
Kaspersky Security Center	Requisitos por confirmar según versión y edición de Kaspersky Security Center; diseño de referencia para 20–26 dispositivos, sin instalación demostrada.	Verificar la versión vigente; considerar la base de datos y el espacio para paquetes y actualizaciones
GLPI en la nube	2 vCPU, 4 GB de RAM y 40 GB SSD	Referencia práctica para ≤ 50 usuarios; incluye respaldos e instantánea del servidor

3.5 Plan de despliegue de agentes al resto de la organización

En el laboratorio se despliegan agentes en un subconjunto representativo; para los 20 equipos se propone el siguiente plan por sistema operativo (verificar en la documentación oficial la compatibilidad de las ediciones elegidas con macOS):

Sistema operativo	Equipos	Método de despliegue	Prueba piloto
Windows 11	12	Paquete MSI distribuido por directiva de grupo o script, con el servidor y el grupo de agentes predefinidos	1 equipo de oficina
Ubuntu Desktop y Server	6	Paquete APT con variables de instalación (servidor y grupo) o gestor de configuración	SRV-C21-STG
macOS	2	Paquete .pkg instalado por script o MDM; documentar el procedimiento si no hay hardware	No disponible en el laboratorio; se documenta el procedimiento de despliegue macOS para una fase futura.

3.6 Servicios transversales y decisión de arquitectura del SIEM

Los servicios transversales se definen una sola vez y se aplican a todos los activos de la Figura 1:

Servicio	Definición	Justificación
Sincronización de hora (NTP)	Todos los equipos, servidores, el NGFW y las VM del SOC usan la misma fuente NTP	Correlación de eventos y trazabilidad (ISO/IEC 27001 A.8.17)
Zona horaria	America/Bogota en todos los activos y en los dashboards	Evita desfases al comparar alertas, logs y tickets

Servicio	Definición	Justificación
Nomenclatura de hosts	PC-, NB-, MB-, UD- y SRV- seguidos de C21 y un consecutivo (por ejemplo, PC-C21-01)	Identifica el activo y el caso en alertas y evidencias
Retención de logs	90 días en el SIEM y 12 meses archivados	Búsquedas rápidas y minimización de datos (Ley 1581); valores de partida de la guía
Respaldos	Copia diaria de la configuración del SIEM y de GLPI, con prueba de restauración	Recuperación ante fallos

Decisión de arquitectura. Se adopta la arquitectura todo en uno (indexer, server y dashboard en SRV-C21-SOC) porque, para 20 agentes y un margen de crecimiento del 25–30 %, cumple las referencias de la guía oficial de Wazuh. La arquitectura distribuida se justifica por alta disponibilidad o volúmenes mayores, que este caso (10 empleados y presupuesto bajo) no exige. El punto único de falla se acepta y se mitiga con instantáneas de la VM y copia de la configuración (sección 3.4).

4. SIEM Wazuh

4.1 Selección y versión

Se eligió Wazuh por ser una plataforma de código abierto que integra SIEM y XDR, con módulos nativos para FIM, SCA, detección de vulnerabilidades y respuesta activa, lo que encaja con el presupuesto bajo del caso. Versión instalada: Wazuh rama 4.14; versión exacta no visible en captura sobre Ubuntu Server 24.04 LTS (fecha de instalación: No ejecutado; supuesto académico hipotético). Referencia: documentación oficial de Wazuh.

4.2 Instalación del servidor (todo en uno)

La captura aportada corresponde a la VM SRV-C21-WAZUH en Oracle VirtualBox y muestra que el instalador todo-en-uno de Wazuh terminó. El instalador registró advertencias de compatibilidad del sistema y de comprobaciones de hardware ignoradas; por ello, se recomienda verificar que la distribución y recursos de la VM cumplan los requisitos oficiales antes de considerar la instalación apta para producción. El procedimiento siguiente se documenta como referencia reproducible, no como evidencia de que todos los controles estén configurados.

```
# Actualizar el sistema y descargar el instalador oficial
sudo apt update && sudo apt -y upgrade
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
# Al finalizar, el instalador muestra las credenciales de admin:
# guardarlas en un gestor de contraseñas; NO publicarlas en este informe
```

Endurecimiento propuesto para el escenario hipotético: limitar el firewall a los puertos necesarios, cambiar las credenciales iniciales, usar llaves para SSH y mantener el sistema actualizado. No se aporta evidencia suficiente para confirmar que todas estas medidas ya estén aplicadas.

```
sudo ufw default deny incoming
sudo ufw allow from 192.168.56.0/24 to any port 22 proto tcp
sudo ufw allow from 192.168.56.0/24 to any port 443 proto tcp
sudo ufw allow from 192.168.56.0/24 to any port 1514 proto tcp
sudo ufw allow from 192.168.56.0/24 to any port 1515 proto tcp
sudo ufw enable
```

Figura 3. Finalización del instalador de Wazuh en SRV-C21-WAZUH.

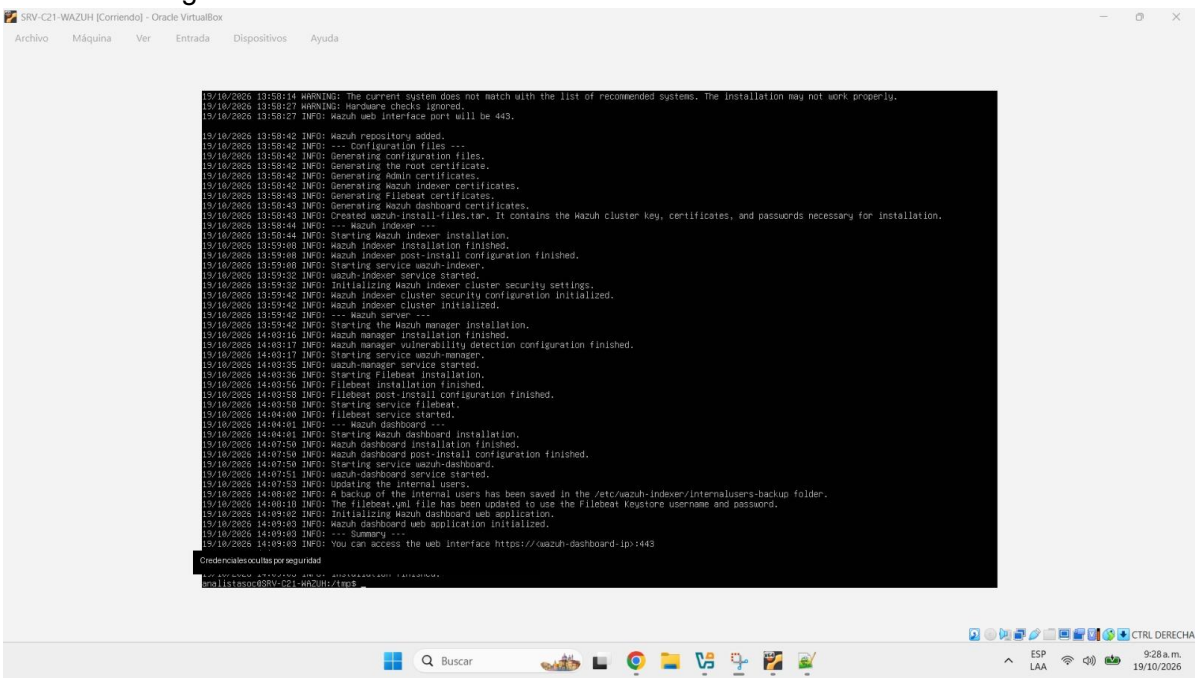
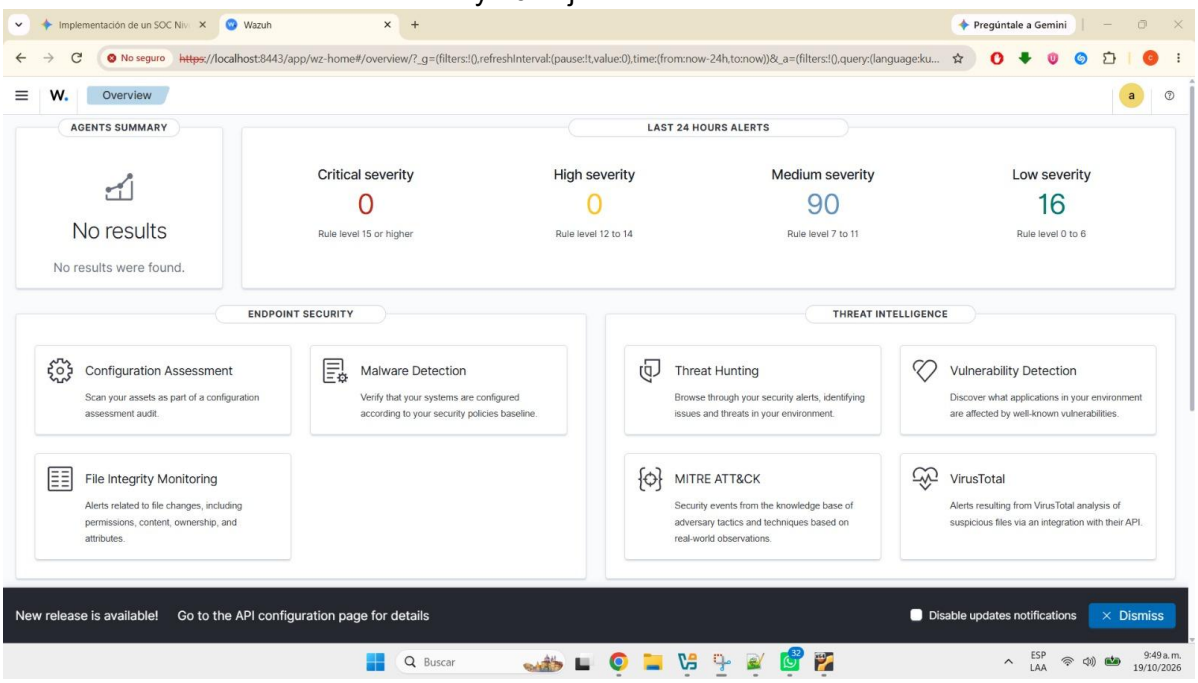


Figura 4. Dashboard de Wazuh abierto en el navegador del equipo anfitrión. La captura muestra 90 alertas medias y 16 bajas en las últimas 24 horas.



Estado de la VM del SIEM. La lista de VM de VirtualBox (captura F01-02) muestra SRV-C21-WAZUH con Ubuntu 25.04 de 64 bits, 2 CPU, 4 GB de RAM, disco de 25 GB y dos adaptadores (NAT y red solo anfitrión). Tres observaciones: (1) Ubuntu 25.04 no es una versión LTS y la guía pide Ubuntu Server LTS; esto explica las advertencias de compatibilidad del instalador, por lo que para la versión final se recomienda reinstalar sobre Ubuntu Server 24.04 LTS; (2) 4 GB de RAM y 2

CPU quedan por debajo del dimensionamiento de la sección 3.4 (4 vCPU, 8 GB); (3) la VM aparece apagada en la captura, por lo que no se evidencian agentes conectados.

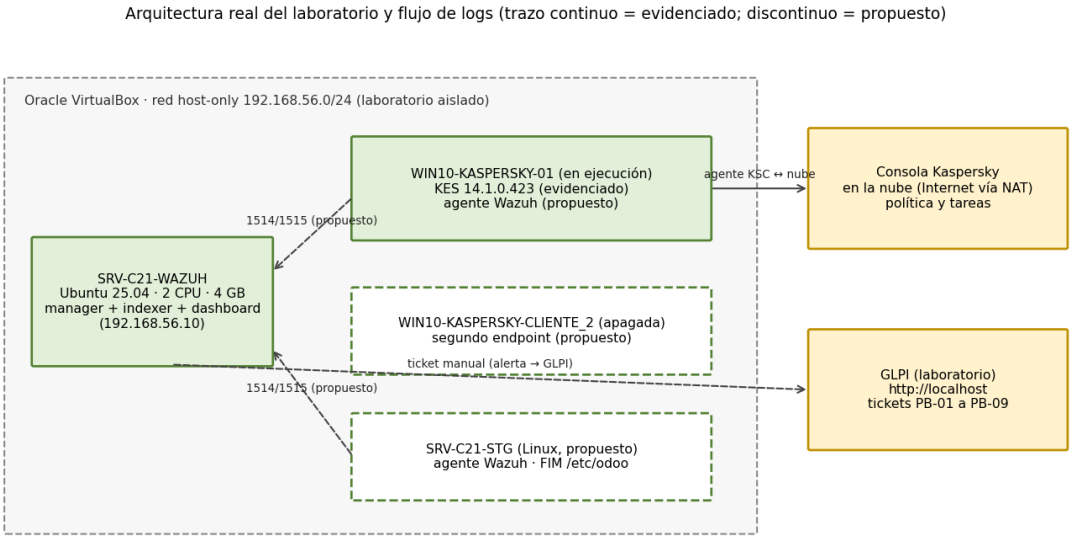


Figura 4B. Arquitectura real del laboratorio y flujo de logs (elaboración propia).

4.3 Grupos y despliegue de agentes

Para el escenario propuesto se organizan los agentes por función mediante los grupos windows-oficina y linux-servidores. Esta separación facilita la aplicación diferenciada de políticas, la revisión de eventos por sistema operativo y el despliegue gradual a los 20 equipos contemplados en el caso.

```
# En el servidor: crear grupos
sudo /var/ossec/bin/agent_groups -a -g windows-oficina -q
sudo /var/ossec/bin/agent_groups -a -g linux-servidores -q
# En el agente Linux (ejemplo, ajustar versión y variables):
# WAZUH_MANAGER='192.168.56.10' WAZUH_AGENT_GROUP='linux-servidores' apt install wazuh-agent
# En el agente Windows (PowerShell como administrador, ejemplo):
# msiexec.exe /i wazuh-agent.msi /q WAZUH_MANAGER='192.168.56.10' WAZUH_AGENT_GROUP='windows-oficina'
```

Agente	Hostname	SO	Grupo	Estado	IP
001	PC-C21-WIN01	Windows 11	windows-oficina	No registrado	No visible
002	SRV-C21-STG	Ubuntu Server 24.04	linux-servidores	No registrado	No visible
003	Agente adicional	VM auxiliar Ubuntu	linux-servidores	No instalado	No visible

4.4 Monitoreo de integridad de archivos (FIM)

Configuración propuesta de FIM: habilitar syscheck en el grupo Linux para vigilar archivos de configuración del ERP y archivos sensibles del sistema, y definir rutas de trabajo de Windows según el alcance. La evidencia aportada no demuestra que esta política se haya aplicado ni que se haya generado una alerta FIM.

```
<agent_config>
  <syscheck>
    <directories check_all="yes" realtime="yes" report_changes="yes">/etc/odoo</directories>
    <directories check_all="yes" realtime="yes">/etc/ssh,/etc/sudoers.d</directories>
    <ignore>/etc/mtab</ignore>
  </syscheck>
</agent_config>
```

Prueba controlada (escenario 3): se modificó el archivo de prueba /etc/odoo/odoo.conf en SRV-C21-STG ([SIMULADO: el archivo representa la configuración del ERP del caso, creado en el laboratorio]) y se verificó la alerta de syscheck (reglas 550 modificado, 554 agregado y 553 eliminado en la instalación por defecto; verificar los identificadores en la versión instalada).

4.5 Evaluación de configuración (SCA)

Diseño propuesto: habilitar SCA con las políticas CIS disponibles para el sistema operativo de cada agente. No se aportaron resultados de evaluación, puntajes ni controles fallidos; estos resultados deberán medirse en el laboratorio si se ejecuta la prueba.

Agente	Política evaluada	Aprobadas	Fallidas	No aplica	Puntaje
SRV-C21-STG	No ejecutada	N/D	N/D	N/D	N/D
PC-C21-WIN01	No ejecutada	N/D	N/D	N/D	N/D

4.6 Detección de vulnerabilidades

Diseño propuesto: habilitar la detección de vulnerabilidades y consultar el inventario de paquetes de los agentes. No se aporta evidencia de un CVE identificado en un agente; el escenario de vulnerabilidad crítica se conserva como caso hipotético y no como hallazgo real.

```
<vulnerability-detection>
  <enabled>yes</enabled>
  <index-status>yes</index-status>
  <feed-update-interval>60m</feed-update-interval>
</vulnerability-detection>
```

Escenario 1 (vulnerabilidad crítica): para el ejercicio se plantea un CVE crítico hipotético en una librería del servidor de demostración. CVE, paquete y versión: no verificados. Agente previsto: SRV-C21-STG. El caso se clasifica como SIMULADO, porque la captura disponible no muestra un hallazgo de vulnerabilidad ni agentes conectados.

4.7 Reglas y decoders personalizados

Propuesta técnica: definir al menos tres reglas y decoders personalizados en los archivos locales de Wazuh y validarlos con wazuh-logtest antes de reiniciar el servicio. No se aportó salida de wazuh-logtest ni una alerta atribuible a estas reglas, por lo que no se afirma que hayan sido implementadas o disparadas.

```
<group name="local,erp_c21,">
  <!-- 100100: Fuerza bruta SSH (escenario 2). Si 6 fallos en 60 s desde la misma IP -->
  <rule id="100100" level="10" frequency="6" timeframe="60">
    <if_matched_sid>5760</if_matched_sid>
    <same_source_ip />
    <description>C21: Fuerza bruta SSH desde la misma IP (6 fallos en 60 s)</description>
    <mitre><id>T1110</id></mitre>
  </rule>
```

```
  <!-- 100101: Cambio en la configuración del ERP (escenario 3) -->
  <rule id="100101" level="12">
    <if_sid>550</if_sid>
    <field name="file">/etc/odoo/odoo.conf</field>
    <description>C21: Modificación del archivo de configuración del ERP</description>
    <group>syscheck,</group>
  </rule>

  <!-- 100102: Inicio de sesión SSH exitoso fuera del horario laboral -->
  <rule id="100102" level="8">
    <if_sid>5715</if_sid>
    <time>7 pm - 7 am</time>
    <description>C21: Inicio de sesión SSH exitoso fuera del horario laboral</description>
  </rule>

  <!-- 100103: Igual, en fin de semana -->
  <rule id="100103" level="8">
    <if_sid>5715</if_sid>
    <weekday>weekends</weekday>
    <description>C21: Inicio de sesión SSH exitoso en fin de semana</description>
  </rule>

  <!-- 100104: Fallo de inicio de sesión en el ERP web (usa el decoder odoo-login) -->
  <rule id="100104" level="5">
    <decoded_as>odoo-login</decoded_as>
    <description>C21: Inicio de sesión fallido en el ERP desde $(srcip)</description>
  </rule>
</group>
```

```
<decoder name="odoo-login">
  <prematch>Login failed for db:</prematch>
  <regex>Login failed for db:(\S+) login:(\S+) from (\S+)</regex>
  <order>extra_data,dstuser,srcip</order>
</decoder>
```

Cada regla se justifica así: 100100 reduce el tiempo de detección de la fuerza bruta frente al umbral por defecto y alimenta la respuesta activa; 100101 eleva la severidad cuando cambia el archivo más sensible del ERP; 100102 y 100103 implementan la regla de horario del playbook PB-04; 100104 aporta visibilidad sobre ataques al propio ERP. Los umbrales se ajustarán con el tráfico real para reducir falsos positivos.

4.8 Respuesta activa (active response)

Respuesta activa propuesta: asociar firewall-drop a la regla de fuerza bruta, con un tiempo limitado y lista blanca para las direcciones administrativas. No se aporta evidencia de una IP bloqueada; la activación debe probarse únicamente entre máquinas propias del laboratorio aislado.

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100100</rules_id>
  <timeout>600</timeout>
</active-response>
```

La prueba se hace exclusivamente desde la VM auxiliar del laboratorio contra SRV-C21-STG. Resultado esperado: la IP origen aparece bloqueada en las reglas de firewall del agente y se registra la alerta de bloqueo (regla 651 en la instalación por defecto; verificar), y el bloqueo expira al cumplirse el tiempo.

4.9 Tableros de control

El dashboard observado presenta un resumen de alertas de las últimas 24 horas y accesos a módulos como SCA, FIM y detección de vulnerabilidades. La captura no acredita que se hayan creado tableros personalizados; estos se describen como propuesta de operación del SOC N1.

Tablero	Contenido	Uso
Alertas por severidad	Conteo por nivel de regla y por agente en las últimas 24 h	Monitoreo y triage
Autenticación	Fallos y éxitos de SSH y de Windows, IP de origen principales	PB-01 y PB-04
FIM	Cambios por ruta, usuario y agente	PB-03
Vulnerabilidades	CVE por severidad y agente, edad de los críticos	PB-09
Cobertura de agentes	Agentes activos y desconectados frente al inventario	KPI de cobertura

4.10 Pruebas controladas y resultados

Prueba	Acción en el laboratorio	Resultado esperado	Resultado obtenido
T-FIM	Modificar /etc/odoo/odoo.conf en SRV-C21-STG	Alerta de FIM (regla 100101)	No ejecutada; alerta no verificada
T-SSH	Intentos fallidos de SSH desde la VM auxiliar	Regla 100100 y bloqueo por active response	No ejecutada; regla no verificada
T-VULN	Revisar el panel de vulnerabilidades	CVE crítico o alto listado	No ejecutada; no hay CVE confirmado
T-SCA	Ejecutar el escaneo de SCA	Puntaje por agente	No ejecutada; sin puntaje disponible
T-HORA	Inicio de sesión SSH fuera de horario (cambiando la hora de la regla en la prueba)	Regla 100102	SIMULADO; no verificado

Limitaciones: el laboratorio usa pocos agentes y un tráfico distinto del real; los umbrales deben recalibrarse tras las primeras semanas de operación.

Estado de la Fase 2. Resumen de cumplimiento de los requisitos de la Fase 2 según la evidencia disponible:

Requisito	Estado	Evidencia
Instalación del servidor (indexer, server, dashboard)	Cumplido con advertencias (Ubuntu no LTS)	Figuras 3 y 4; captura F01-02
Agentes Windows y Linux conectados	No evidenciado	—
FIM, SCA y detección de vulnerabilidades	Configuración diseñada; sin resultados	Secciones 4.4 a 4.6
Al menos 3 reglas y decoders personalizados	5 reglas y 1 decoder diseñados; sin salida de wazuh-logtest	Sección 4.7

Respuesta activa	Diseñada (firewall-drop, 600 s); sin bloqueo observado	Sección 4.8
Tableros de control	Dashboard por defecto; sin tableros personalizados	Figura 4

5. EDR/XDR Kaspersky

5.1 Selección y justificación de la edición

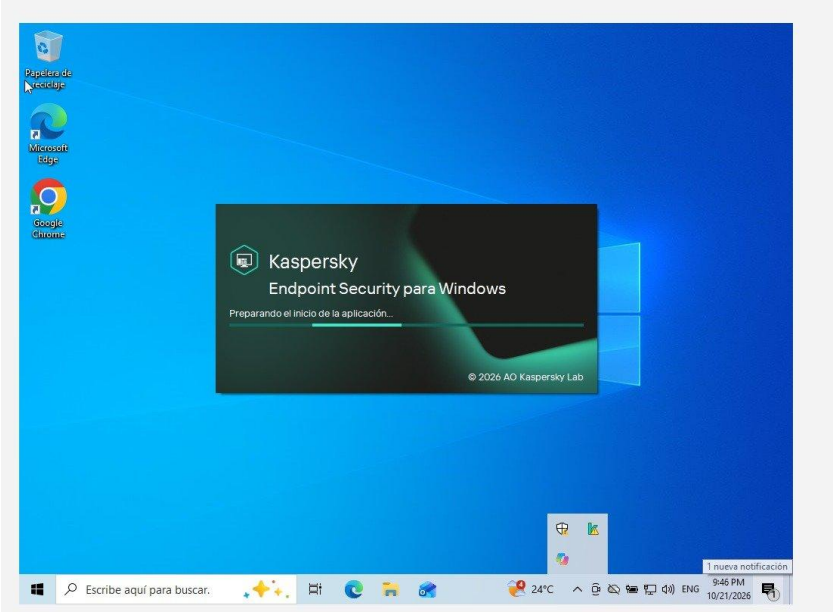
Producto utilizado. En el laboratorio se usó Kaspersky Endpoint Security para Windows, versión 14.1.0.423, administrado desde una consola en la nube (servidor s231.cloud.kaspersky.com), como se ve en la pantalla de supervisión del producto (captura F03-02). La edición y el tipo de licencia (prueba o comercial) y su vencimiento no son visibles en las capturas: deben confirmarse en la consola antes de la entrega. La comparación de ediciones siguiente es de diseño y usa costos estimados.

Criterio	Edición básica de protección con EDR	Edición con EDR ampliado	Justificación para C21
Protección en tiempo real y control de dispositivos, web y firewall	Protección de endpoint empresarial	Protección endpoint con EDR	Requisito del parcial y del riesgo de malware y USB
Investigación y respuesta (EDR)	Protección en tiempo real y controles básicos	Protección más investigación y respuesta	El N1 necesita aislar equipos y ver la línea de tiempo
Soporte de Linux y macOS	Windows: por confirmar; Linux/macOS: verificar	Windows: por confirmar; Linux/macOS: verificar	6 equipos Ubuntu y 2 macOS en el inventario
Consola	Consola en la nube (la usada en el laboratorio)	Consola en la nube (usada en el laboratorio)	Menor costo operativo en una pyme
Costo por equipo (COP, cotización)	COP 110.000/equipo/año (estimación)	COP 180.000/equipo/año (estimación)	Tope OPEX ≤ COP 1,5 M/mes

Edición seleccionada para el diseño: Kaspersky Endpoint Security for Business con capacidades EDR, edición y versión exactas por confirmar antes de una implementación real. Se elige como referencia porque el caso requiere protección en tiempo real, control de USB y web, firewall y respuesta ante malware. La estimación presupuestal contempla 20 equipos, pero la compatibilidad por sistema operativo y el precio deben validarse con el fabricante o distribuidor autorizado. No se afirma que la consola o los agentes estén instalados.

5.2 Instalación de la consola de administración

Consola de administración. Se utilizó la consola de administración alojada en la nube de Kaspersky, por lo que no se instaló un servidor de administración propio. Ventajas para la pyme: no requiere una VM dedicada ni mantenimiento del servidor de administración; riesgo: la consola depende de Internet y de la cuenta del proveedor, que debe protegerse con autenticación en dos pasos. La VM SRV-C21-KSC de la VLAN 90 del diseño de producción solo sería necesaria si se opta por una consola local. La captura de la propia consola web no se aportó; solo se evidencia el estado «Administrado por la directiva de seguridad» en el equipo.



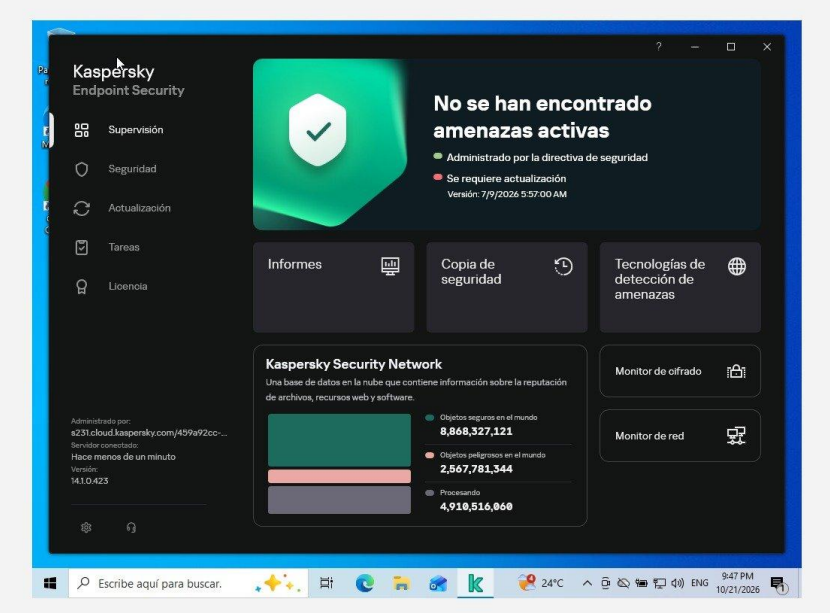
Captura F03-01. Inicio de Kaspersky Endpoint Security para Windows en WIN10-KASPERSKY-01. Hora: 9:46 p. m., 21/10/2026.

5.3 Despliegue de agentes

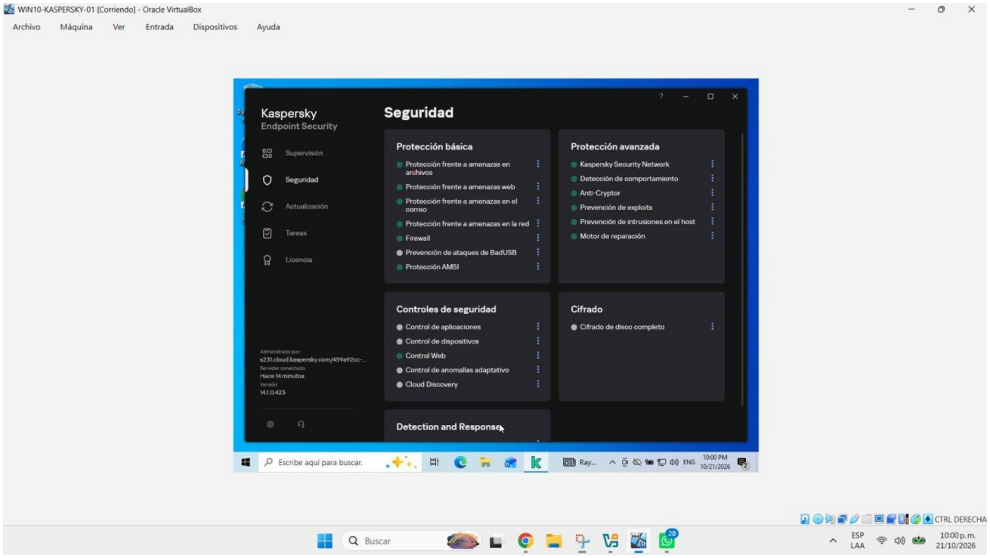
Despliegue de agentes. El agente y la protección se instalaron en la VM WIN10-KASPERSKY-01 (en el informe, el equivalente del equipo de oficina PC-C21-WIN01). La pantalla de supervisión indica que el equipo está administrado por la directiva de seguridad y que el servidor de administración se conectó «hace menos de un minuto» (capturas F03-02 y F03-03). La segunda VM WIN10-KASPERSKY-CLIENTE_2 existe pero estaba apagada. Para los 20 equipos se propone distribuir paquetes de instalación desde la consola y verificar la cobertura con el KPI de agentes activos.

Equipo	SO	Agente de administración	Protección	Estado	Última conexión
WIN10-KASPERSKY-01	Windows 10	Conectado a la consola en la nube	KES 14.1.0.423; sin amenazas activas	Activo	21/10/2026, 9:47 p. m.

Equipo	SO	Agente de administración	Protección	Estado	Última conexión
WIN10-KASPERSKY-CLIENTE_2	Windows 10	Pendiente	Pendiente	VM apagada	No conectado



Captura F03-02. Pantalla de supervisión de KES: «No se han encontrado amenazas activas», administrado por la directiva de seguridad, versión 14.1.0.423. Hora: 9:47 p. m., 21/10/2026.



Captura F03-03. Componentes de seguridad de KES en WIN10-KASPERSKY-01 (VirtualBox, en ejecución). Hora: 10:00 p. m., 21/10/2026.

5.4 Políticas aplicadas

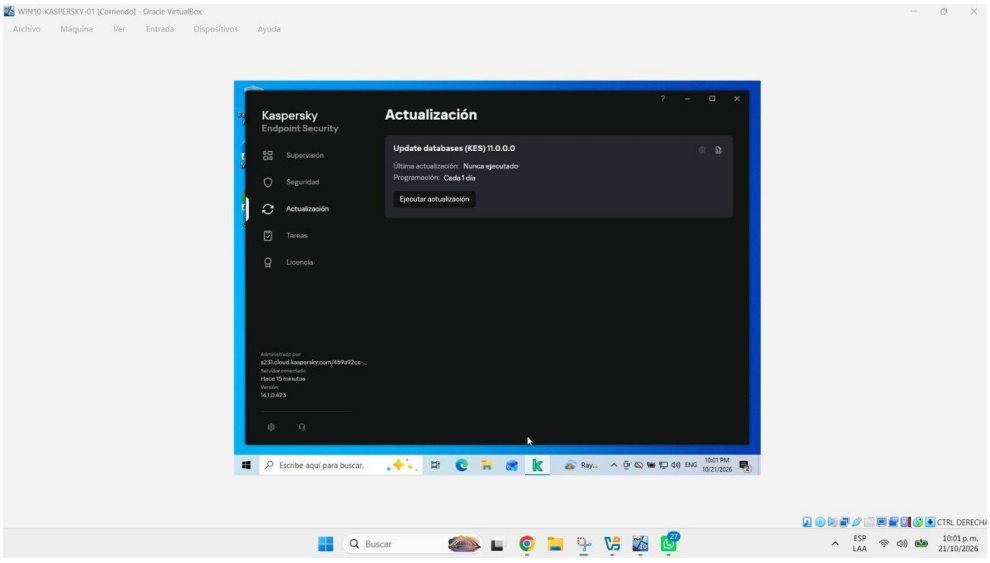
Evidencia. En el cliente (captura F03-03) se observan los componentes siguientes: protección frente a amenazas en archivos, web, correo y red; firewall; prevención de ataques BadUSB y AMSI;

protección avanzada (Kaspersky Security Network, detección de comportamiento, Anti-Cryptor, prevención de exploits, prevención de intrusiones en el host y motor de reparación); controles de aplicaciones, dispositivos, web y de anomalías adaptativo; cifrado de disco completo y el componente Detection and Response. La política exacta aplicada desde la consola (acciones, lista blanca de USB y categorías web) no se capturó y se documenta en la tabla siguiente como diseño.

Componente	Estaciones y portátiles Windows	Servidores Linux	Justificación
Protección en tiempo real (archivos, web, correo)	Activa, acción: desinfectar y, si no es posible, poner en cuarentena	Activa para archivos	ISO/IEC 27001 A.8.7
Control de dispositivos (USB)	Bloquear almacenamiento extraíble; permitir solo dispositivos de la lista blanca aprobada por el Responsable del SOC	No aplica (servidores en VLAN 20)	Evita fuga de datos de clientes y malware por USB (PB-05)
Control web	Bloquear categorías de malware, phishing y sitios de descarga no confiables; registrar el resto	No aplica	Reduce el riesgo de phishing en consultores
Firewall	Perfil de red de oficina: bloquear conexiones entrantes no solicitadas y permitir el tráfico hacia el ERP y la VPN	Complementa a ufw	Defensa en profundidad
Protección contra ataques de red y comportamiento	Activa	Activa	Detección de comportamientos como cifrado masivo o minería
Autoprotección y contraseña de desinstalación	Activa	Activa	Evita que un usuario o un malware desactive el EDR
Envío de eventos a Wazuh	Detecciones y eventos de control de dispositivos	Detecciones	Visibilidad central (sección 5.7)

5.5 Tareas programadas

Evidencia. La captura F03-04 muestra la tarea «Update databases (KES)» con programación «Cada 1 día» y última actualización «Nunca ejecutado»; el producto indica además «Se requiere actualización». Debe ejecutarse la actualización manual antes de la prueba EICAR para que la detección use las bases vigentes.



Captura F03-04. Pantalla «Actualización» de KES: tarea Update databases con programación diaria, aún sin ejecutar. Hora: 10:01 p. m., 21/10/2026.

Tarea	Frecuencia	Alcance	Objetivo
Actualización de bases y módulos	Diaria y al iniciar	Todos los equipos	Mantener la detección actualizada
Análisis rápido de áreas críticas	Diaria, 12:30	Windows	Detección temprana con bajo impacto
Análisis completo	Semanal, domingo 22:00	Todos los equipos	Revisión profunda fuera del horario laboral
Informe de estado de protección	Semanal	Consola	Alimentar KPIs de cobertura

5.6 Exclusiones y su justificación

Las exclusiones reducen la cobertura, por lo que se mantienen mínimas, específicas (ruta o proceso exacto, nunca unidades completas) y aprobadas por el Responsable del SOC mediante un ticket de cambio. Propuesta para el caso (confirmar si realmente se aplican en el laboratorio):

Exclusión propuesta	Alcance	Justificación	Control compensatorio	Aprobador	Revisión
Directorio de datos de la base de datos en el servidor SRV-C21-DB	Solo el directorio de datos, en el análisis en tiempo real	Evitar degradación del rendimiento y bloqueo de archivos de la base de datos	Análisis completo programado fuera de horario, FIM de Wazuh sobre la configuración y monitoreo de procesos	Responsable del SOC	Trimestral
No se aplicaron más exclusiones en el escenario documentado.	No aplica	No aplica	No aplica	No aplica	No aplica

No se excluyen carpetas de compilación, descargas ni directorios de usuario, para no crear zonas sin cobertura en las estaciones de los consultores y desarrolladores.

5.7 Integración de eventos con Wazuh (Syslog/CEF)

Integración propuesta, no comprobada: la consola Kaspersky exportaría eventos a un receptor syslog en formato CEF y Wazuh los procesaría mediante un decoder y una regla. No se aportó un mensaje CEF real ni evidencia de recepción.

Alternativa para consola en la nube. Como la consola es de nube, la exportación syslog/CEF puede no estar disponible desde ella o requerir un conector; debe verificarse en la documentación vigente. Alternativa: instalar el agente de Wazuh en WIN10-KASPERSKY-01 y recolectar el registro de eventos de Windows de Kaspersky (canal eventchannel; confirmar el nombre exacto del canal en el Visor de eventos), con una regla propia sobre los eventos de detección.

1. En la consola Kaspersky, la configuración propuesta consiste en exportar eventos a syslog/CEF hacia el receptor del SIEM por el puerto 514, una vez confirmada la ruta del menú para la edición seleccionada. No se aportó evidencia de envío ni de recepción de eventos.
2. En el servidor Wazuh: habilitar un receptor syslog limitado a la IP de la consola.
3. Verificar la llegada de mensajes y escribir el decoder y la regla a partir de un mensaje real.

```
<!-- /var/ossec/etc/ossec.conf (servidor Wazuh) -->
<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>udp</protocol>
  <allowed-ips>192.168.56.20</allowed-ips>
</remote>
```

```
<!-- Esqueleto: AJUSTAR con el mensaje CEF real recibido (probar con wazuh-logtest) -->
<decoder name="kaspersky-cef">
  <prematch>CEF:0\|Kaspersky</prematch>
</decoder>

<rule id="100200" level="10">
  <decoded_as>kaspersky-cef</decoded_as>
  <description>C21: Evento de detección de Kaspersky recibido por syslog</description>
</rule>
```

5.8 Prueba de detección con el archivo EICAR

EICAR es un archivo de prueba estándar e inofensivo que los antivirus detectan como si fuera malware. La prueba se realiza solo en la VM PC-C21-WIN01, obteniendo el archivo del sitio oficial de EICAR dentro de la red de laboratorio, y está autorizada en la carta (Anexo H).

Paso	Evidencia esperada	Resultado
Descargar o crear el archivo EICAR en PC-C21-WIN01	Alerta emergente o bloqueo del producto	No ejecutado; supuesto hipotético
Ver la detección en la consola	Evento con nombre de amenaza, ruta, hash, usuario y acción tomada	No ejecutado; supuesto hipotético
Ver el evento en Wazuh	Alerta de la regla 100200	No ejecutado; supuesto hipotético
Registrar el ticket en GLPI (T-03) y aplicar PB-02	Ticket con triage completo	No ejecutado; supuesto hipotético

Limitaciones: la prueba EICAR no se ejecutó y no se evidencia el envío de eventos a Wazuh; la licencia, su tipo y su vencimiento no son visibles en las capturas. Las funciones EDR dependerán de la edición finalmente asignada.

Estado de la Fase 3. Resumen de cumplimiento de los requisitos de la Fase 3 según la evidencia disponible:

Requisito	Estado	Evidencia
Consola de administración	Cumplido: consola en la nube	Capturas F03-02 y F03-03
Al menos un agente conectado	Cumplido: WIN10-KASPERSKY-01	Capturas F03-02 y F03-03
Políticas (tiempo real, USB, web, firewall)	Parcial: componentes visibles en el cliente; política de la consola sin captura	Captura F03-03
Tareas programadas	Parcial: actualización diaria definida; sin ejecución	Captura F03-04
Exclusiones justificadas	Documentadas en la sección 5.6; sin captura	—
Prueba EICAR	No evidenciada	—
Envío de alertas a Wazuh	No evidenciado	—

6. GLPI en la nube

6.1 Diseño de la solución

GLPI es la mesa de servicio y el inventario del SOC: registra cada alerta como ticket, vincula el activo afectado, controla los SLA y publica los playbooks en su base de conocimiento. Es el único componente expuesto a Internet, por lo que se despliega con HTTPS y controles de acceso estrictos (sección 5.4 de la guía) y sin datos reales.

Elemento	Decisión
Proveedor y región	Laboratorio: instalación propia de GLPI en el equipo del consultor (acceso por localhost). Evidencia de interfaz alojada: instancia de demostración de GLPI Network (nube, región US). Producción propuesta: VM en proveedor cloud; región por definir según residencia de datos y costo.
Instancia	VM Ubuntu Server 24.04 LTS, 2 vCPU, 4 GB RAM, 40 GB (referencia para ≤ 50 usuarios)
Pila	Apache o Nginx, PHP y MariaDB en las versiones requeridas por la versión de GLPI instalada
Versión de GLPI	Instalada con el asistente web oficial de GLPI (6 pasos, ver capturas F04-02 y F04-03); confirmar la versión exacta en Configuración › General antes de la entrega.
Nombre de dominio	Laboratorio: http://localhost. Producción: glpi.erppyme.example (dominio reservado para documentación) con certificado ACME/Let's Encrypt.
Certificado	HTTPS con certificado válido y redirección de HTTP a HTTPS
Acceso administrativo	SSH solo con llave y desde IP autorizada

> ***ATENCIÓN con las capturas:*** *oculta o tacha la IP pública real y el dominio real de la instancia, las llaves, los tokens y las contraseñas en todas las capturas, el video y el repositorio. Exponerlos penaliza –5 puntos por incidencia.*

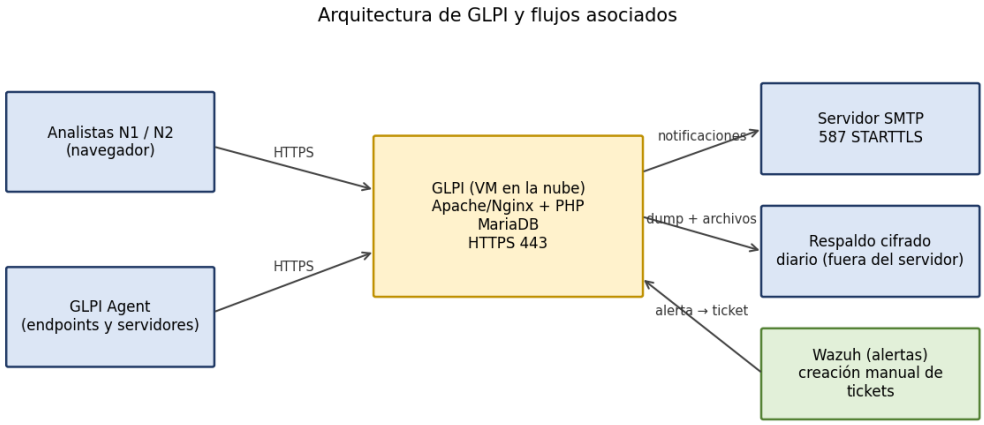
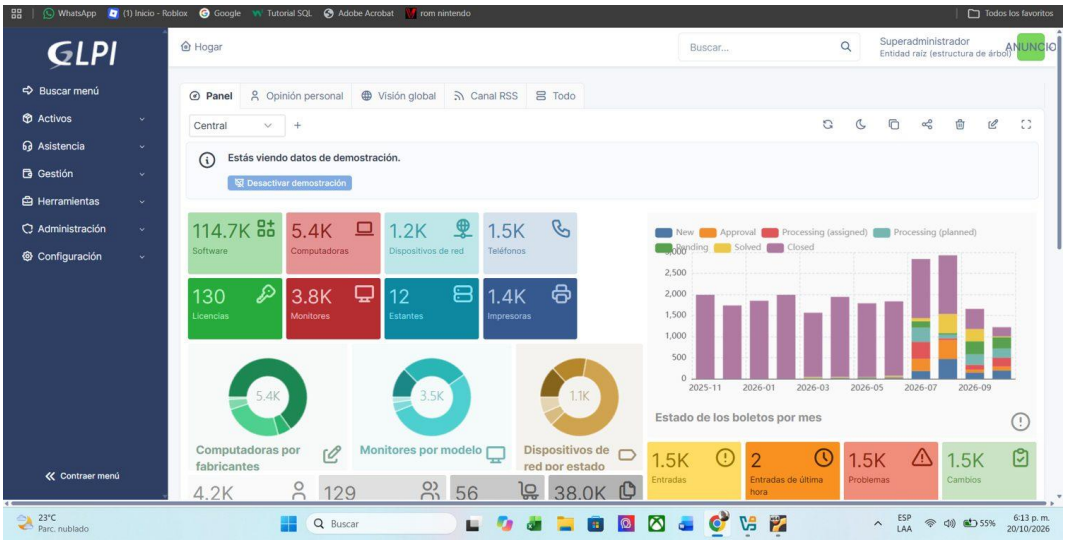


Figura F04-A. Arquitectura propuesta de GLPI en la nube y flujos asociados (elaboración propia).



Captura F04-01. Instancia de demostración de GLPI Network (nube): interfaz y panel con datos de demostración. Dominio de la instancia omitido. Hora del equipo visible en la barra de tareas (20/10/2026).

6.2 Endurecimiento del servidor en la nube

Control	Acción
Acceso SSH	Autenticación solo por llave, sin inicio de sesión de root y sin contraseñas; puerto 22 limitado a la IP autorizada
Firewall	Permitir solo 80 y 443 desde Internet (80 únicamente para la redirección y el certificado) y 22 desde la IP autorizada
Prevención de fuerza bruta	fail2ban en SSH
Actualizaciones	Actualizaciones automáticas de seguridad

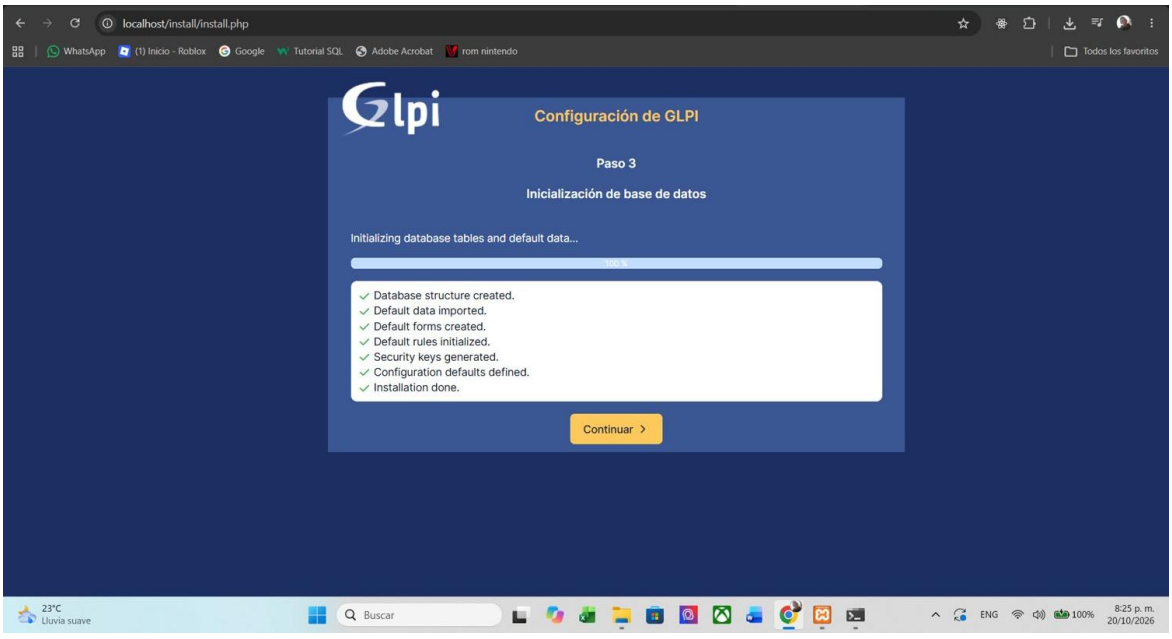
Control	Acción
Base de datos	Ejecutar el endurecimiento inicial de MariaDB, usuario dedicado para GLPI con permisos mínimos, sin acceso remoto
GLPI	Cambiar o deshabilitar las cuentas por defecto, eliminar el instalador tras la instalación, permisos mínimos en los directorios y cookies seguras
Monitoreo	Agente de Wazuh en la VM de GLPI, con FIM sobre su configuración (opcional, recomendado)

```
# Ejemplo (ajustar a tu entorno; no publicar IP reales)
sudo ufw default deny incoming
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw allow from 203.0.113.10 to any port 22 proto tcp   # IP de documentación
sudo ufw enable
```

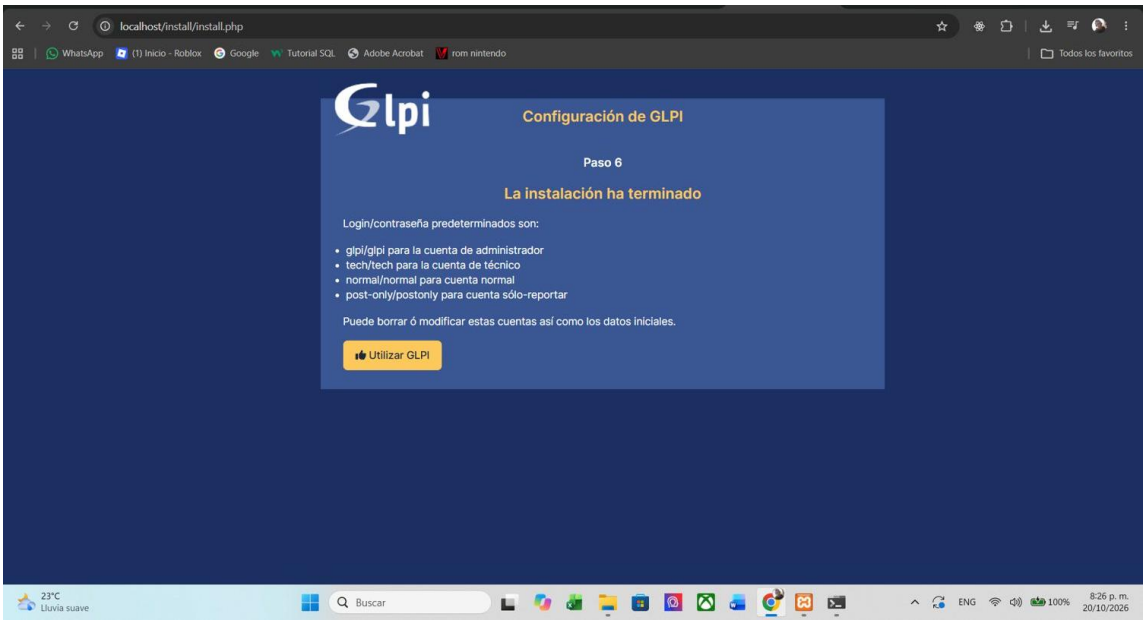
6.3 Instalación web y HTTPS

Instalación realizada en laboratorio. El instalador web de GLPI se ejecutó en el equipo del laboratorio (http://localhost/install/install.php). Se completaron el paso 3 (inicialización de la base de datos: estructura, datos por defecto, reglas y claves de seguridad generadas) y el paso 6, «La instalación ha terminado» (capturas F04-02 y F04-03). El tablero posterior mostró la advertencia de GLPI de cambiar las contraseñas predeterminadas de las cuentas glpi, tech, normal y post-only; esas cuentas deben cambiarse o desactivarse y el directorio de instalación eliminarse antes de cualquier uso productivo. La pantalla de autenticación (captura F04-04) usa la base de datos interna de GLPI como fuente de inicio de sesión.

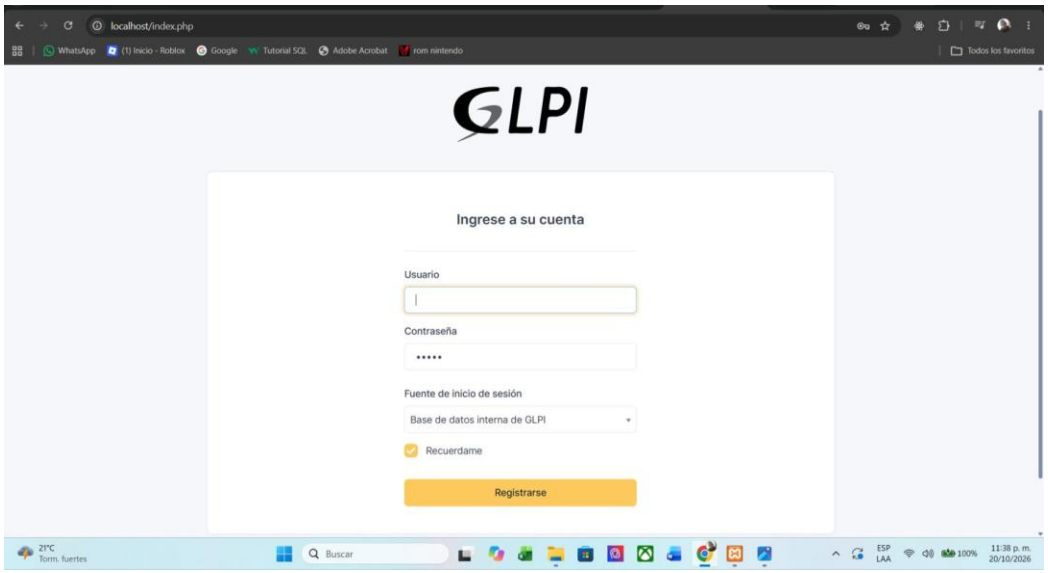
Alcance de la evidencia. El laboratorio se accede por HTTP en localhost. La publicación con HTTPS, certificado válido, SSH restringido y fail2ban (sección 6.2) corresponde a la instancia en la nube de producción y no se evidencia en estas capturas; por eso aparece como no cumplida en la lista de verificación de la sección 6.6.



Captura F04-02. Instalador de GLPI: inicialización de la base de datos finalizada (paso 3). Hora del equipo: 8:25 p. m., 20/10/2026.



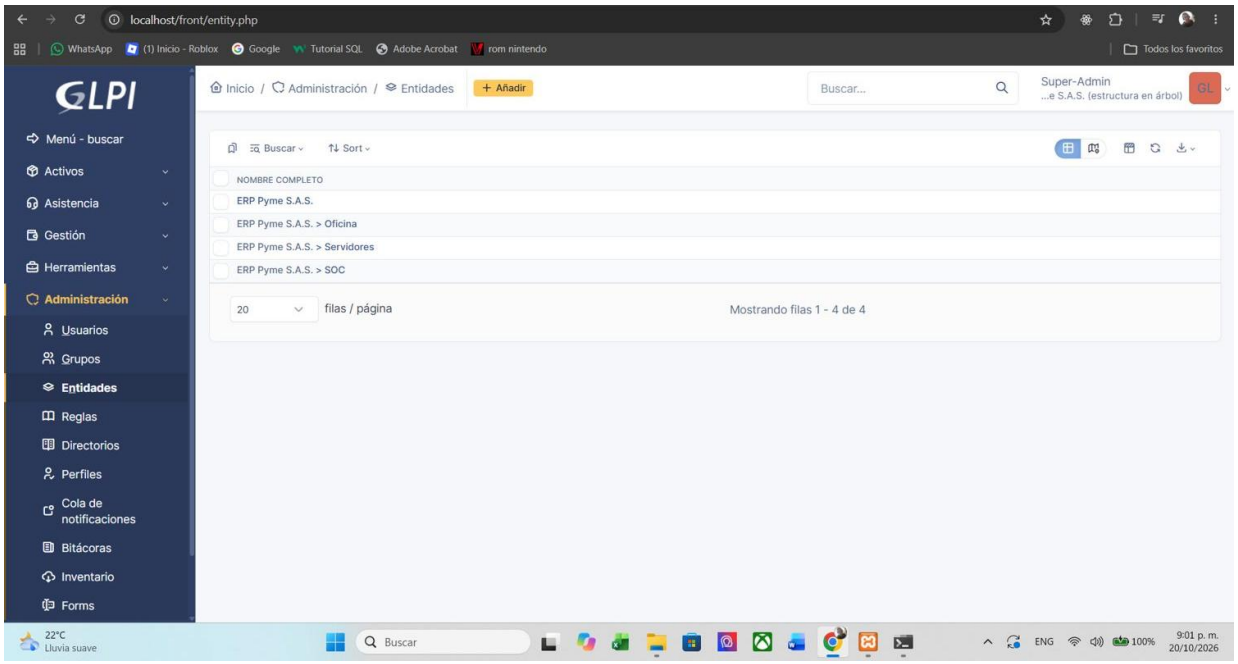
Captura F04-03. Instalador de GLPI: «La instalación ha terminado» (paso 6). Hora del equipo: 8:26 p. m., 20/10/2026.



Captura F04-04. Pantalla de autenticación de GLPI del laboratorio (sin credenciales visibles).

6.4 Configuración para la puesta en marcha

Entidades. Entidad raíz «ERP Pyme S.A.S.» con subentidades Oficina, Servidores y SOC (alertas de seguridad); creadas en GLPI (captura F04-05).

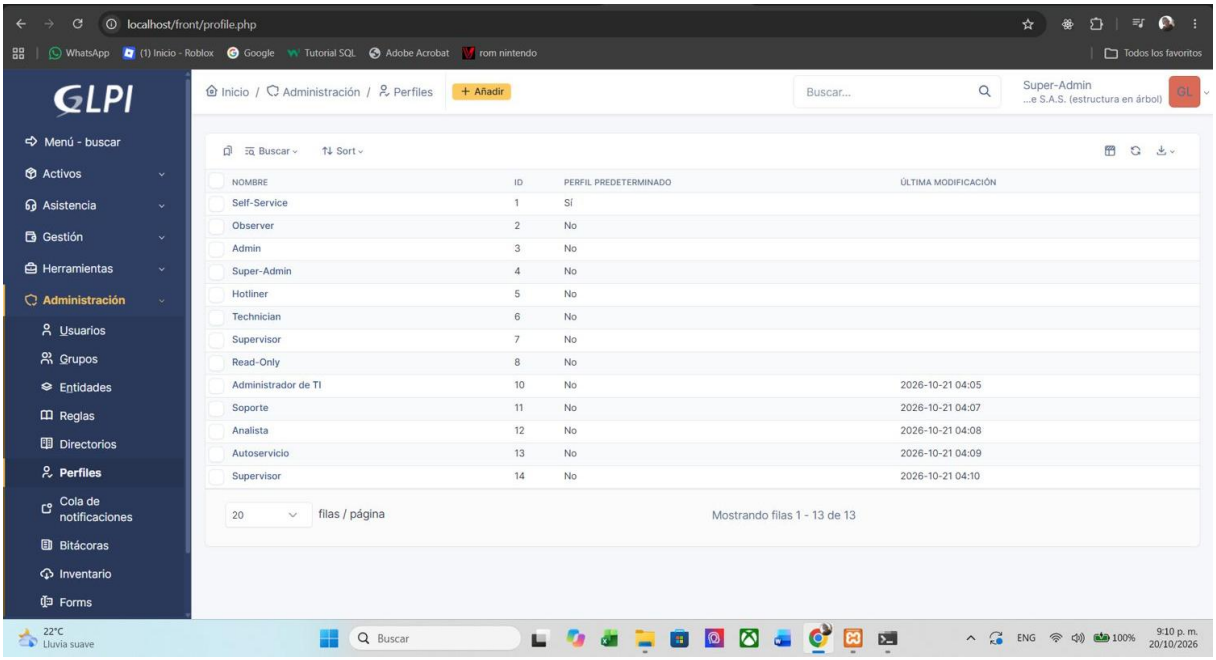


Captura F04-05. Entidades de GLPI: ERP Pyme S.A.S. › Oficina, Servidores y SOC. Hora: 9:01 p. m., 20/10/2026.

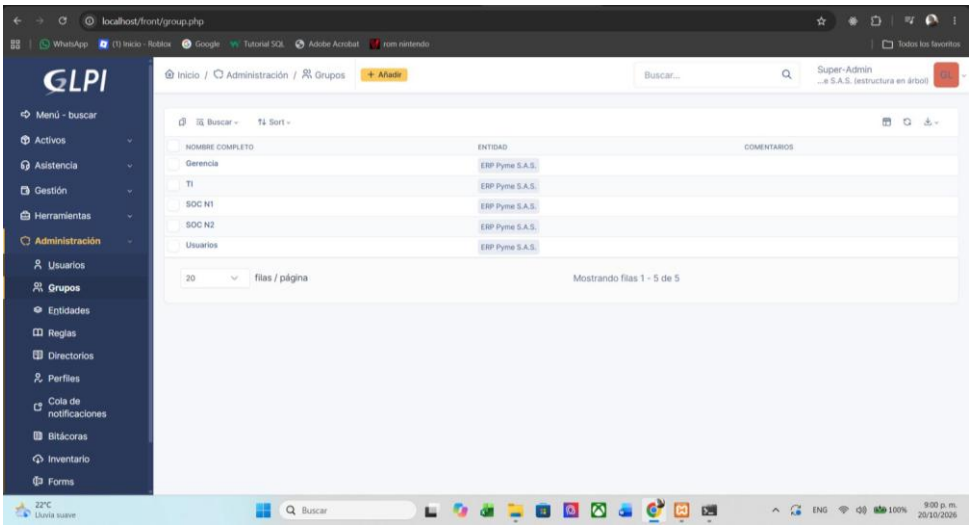
Perfiles.

Perfil	Rol	Permisos clave
Super-Admin	Responsable del SOC	Configuración, reglas, SLA y reportes
Analista	Analista SOC N1	Crear y gestionar tickets de seguridad, ver inventario y base de conocimiento; sin acceso a configuración
Soporte	N2 interno o tercero	Gestionar tickets escalados
Administrador de TI	Cambios en sistemas	Inventario y tickets de cambio
Supervisor	Directivos	Lectura de reportes
Autoservicio	Empleados	Abrir y consultar sus tickets (autoservicio)

Se crearon en GLPI los perfiles Administrador de TI, Soporte, Analista, Autoservicio y Supervisor, además de los perfiles predeterminados (captura F04-06). Grupos creados: Gerencia, TI, SOC N1, SOC N2 y Usuarios (captura F04-07).



Captura F04-06. Perfiles de GLPI (perfiles personalizados con fecha de modificación 21/10/2026).

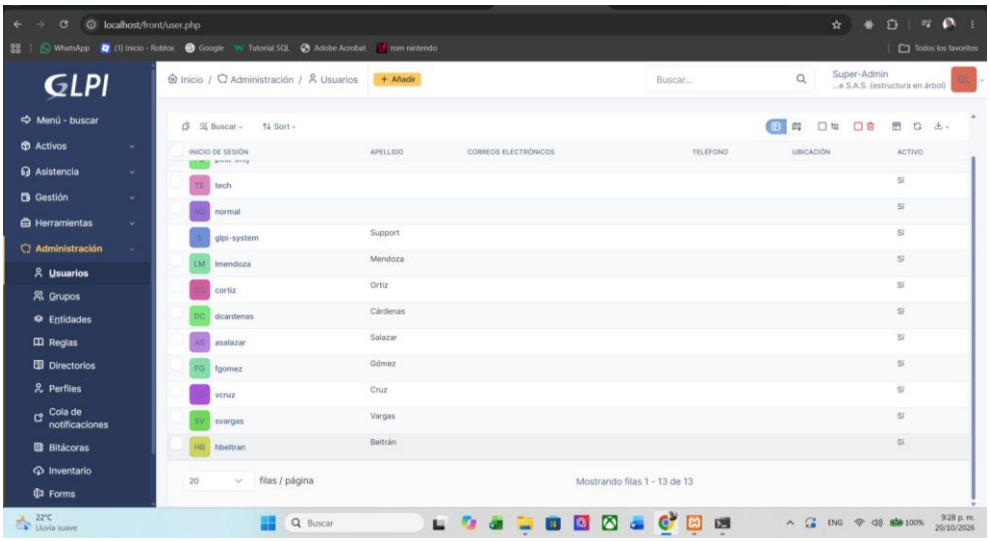


Captura F04-07. Grupos de GLPI: Gerencia, TI, SOC N1, SOC N2 y Usuarios. Hora: 9:00 p. m., 20/10/2026.

Usuarios ficticios (10). Todos los nombres y correos son inventados y usan el dominio reservado erppyme.example. En GLPI hay 13 cuentas: 5 predeterminadas (glpi, tech, normal, post-only y glpi-system) y 8 usuarios ficticios creados (captura F04-08); los 2 restantes de los 10 previstos están pendientes de crear.

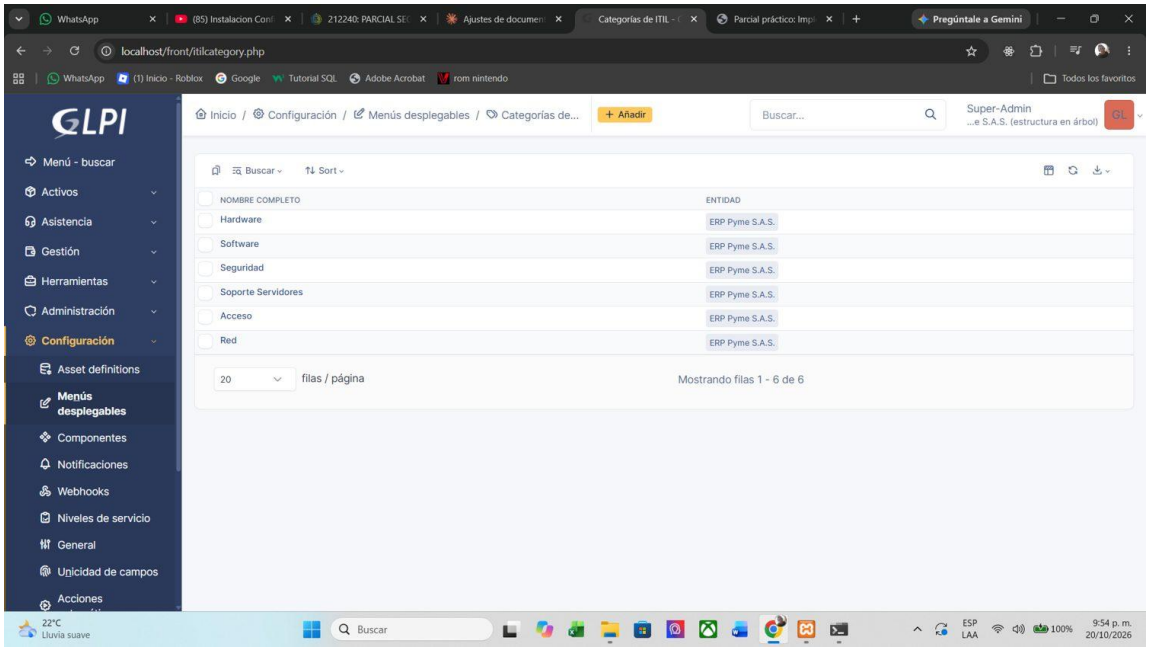
N.º	Usuario ficticio	Cargo	Perfil	Correo
1	Laura Mendoza (lmendoza)	Gerente general	Supervisor	lmendoza@erppyme.example
2	Camilo Ortiz (cortiz)	Gerente de proyectos	Supervisor	cortiz@erppyme.example

N.º	Usuario ficticio	Cargo	Perfil	Correo
3	Diana Cárdenas (dcardenas)	Administradora de TI	Administrador de TI	dcardenas@erppyme.example
4	Andrés Salazar (asalazar)	Responsable del SOC	Super-Admin	asalazar@erppyme.example
5	Felipe Gómez (fgomez)	Analista SOC N1 (turno A)	Analista	fgomez@erppyme.example
6	Valentina Cruz (vcruz)	Analista SOC N1 (turno B)	Analista	vcruz@erppyme.example
7	Sergio Vargas (svargas)	Consultor funcional	Autoservicio	svargas@erppyme.example
8	Héctor Beltrán (hbeltran)	Soporte N2 (externo)	Soporte	hbeltran@erppyme.example
9	Natalia Pardo	Consultora funcional	Autoservicio	Vacio
10	Mateo Ríos	Desarrollador	Autoservicio	Vacio



Captura F04-08. Usuarios de GLPI (8 ficticios creados más cuentas predeterminadas). Hora: 9:28 p. m., 20/10/2026.

Categorías ITIL. Tipos: Incidente, Solicitud, Problema y Cambio. Categorías creadas en GLPI: Hardware, Software, Seguridad, Soporte Servidores, Acceso y Red (captura F04-09). Subcategorías de seguridad propuestas bajo «Seguridad»: Fuerza bruta, Malware, Integridad de archivos (FIM), Vulnerabilidades, Acceso anómalo, Dispositivos USB y Phishing.



Captura F04-09. Categorías ITIL de GLPI. Hora: 9:54 p. m., 20/10/2026.

SLA y OLA propuestos. Se configurarían con los tiempos de la tabla del capítulo 8, calendario laboral (lunes a viernes, 7:00–19:00, America/Bogota) y guardia 24×7 para severidades crítica y alta. El N1 entregaría al N2 un escalamiento completo dentro del plazo definido.

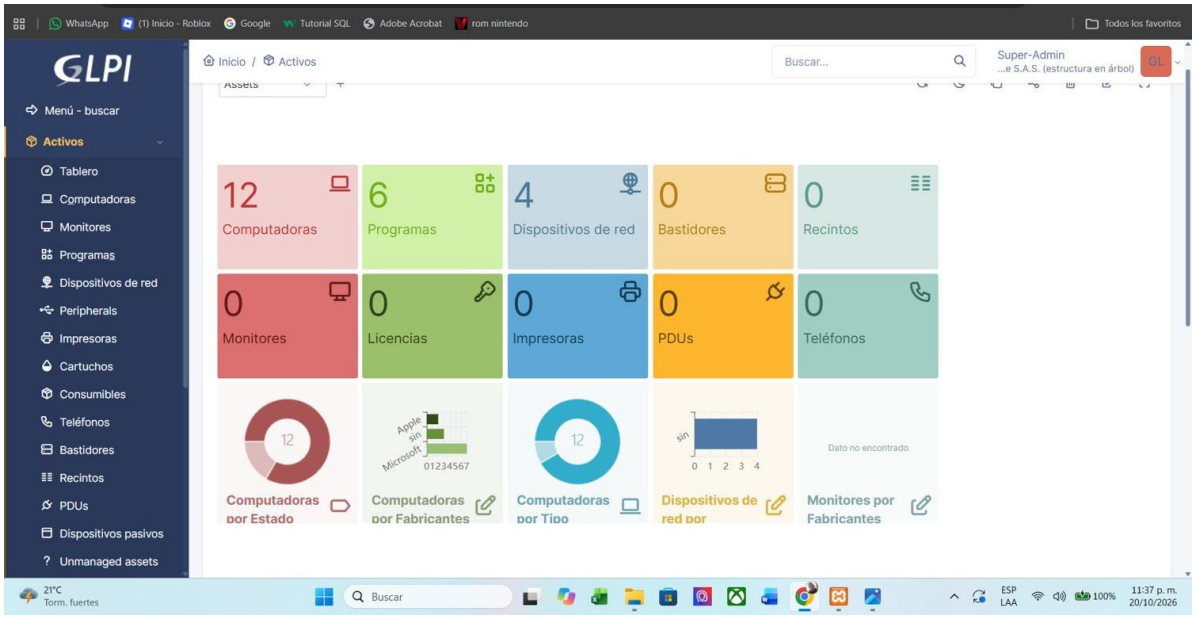
Prioridad GLPI	Reconocer (TTO)	Resolver o contener (TTR)	Calendario
Muy alta (crítica)	15 min	4 h	24×7
Alta	30 min	8 h	Laboral y guardia
Media	2 h	24 h	Laboral
Baja	8 h hábiles	72 h	Laboral
Muy baja (informativa)	1 día hábil	5 días hábiles	Laboral

Plantillas de tickets propuestas. Se crearían plantillas con los campos del Anexo C: «Seguridad – alerta SIEM», «Seguridad – alerta EDR», «Vulnerabilidad» y «Cambio». Campos obligatorios sugeridos: origen, ID de alerta, activo afectado, hora, clasificación y decisión.

Reglas de negocio. (1) Los tickets de la entidad SOC se asignan por categoría al grupo Analista N1. (2) La prioridad se calcula con la matriz urgencia × impacto y asigna el SLA correspondiente. (3) Si el campo «Escalado a N2» es Sí, el ticket se asigna al grupo Soporte N2. (4) Las prioridades muy alta y alta notifican al Responsable del SOC.

Notificaciones por correo propuestas. Se configuraría SMTP con una cuenta creada para el ejercicio, no una cuenta personal, y plantillas para nuevo ticket, asignación, vencimiento del SLA y solución.

Inventario. El panel de activos de GLPI muestra 12 computadoras, 4 dispositivos de red y 6 programas cargados (captura F04-10). La instalación de GLPI Agent en PC-C21-WIN01 y SRV-C21-STG apuntando al servidor por HTTPS queda como diseño propuesto; para los 20 equipos se propone un paquete con URL y etiqueta por VLAN.

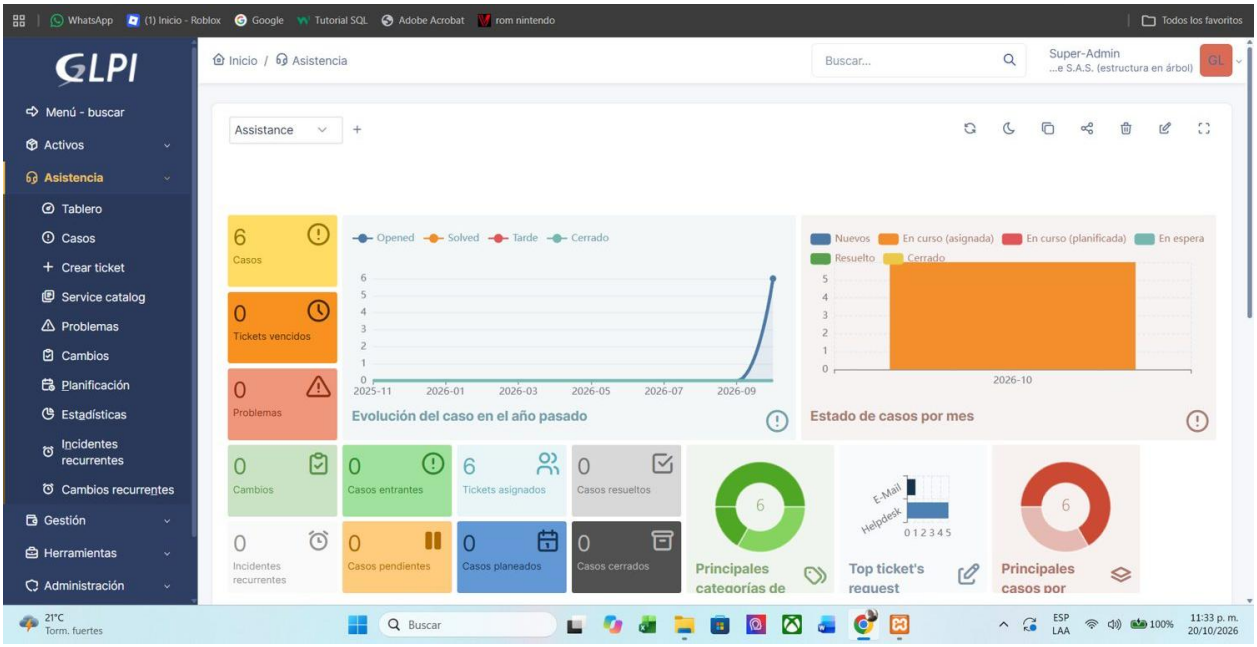


Captura F04-10. Panel de activos de GLPI (12 computadoras, 4 dispositivos de red). Hora: 11:37 p. m., 20/10/2026.

Base de conocimiento (12 artículos).

N.º	Artículo	Tipo
1	PB-01 Fuerza bruta SSH / RDP	Playbook
2	PB-02 Malware detectado por el EDR	Playbook
3	PB-03 Cambio en archivos críticos (FIM)	Playbook
4	PB-04 Inicio de sesión fuera de horario o anómalo	Playbook
5	PB-05 Uso de USB no autorizado	Playbook
6	PB-06 Phishing reportado	Playbook
7	PB-07 Escaneo de puertos / reconocimiento	Playbook
8	PB-08 Cuenta privilegiada nueva o elevación de privilegios	Playbook
9	PB-09 Vulnerabilidad crítica	Playbook
10	Manual del SOC N1: flujo de triage y severidades	Procedimiento
11	Plantilla de escalamiento a N2 y matriz de contactos	Procedimiento
12	Política de enmascaramiento de datos en entornos de prueba	Política

Reportes. Tickets por categoría y por severidad, cumplimiento de SLA, MTTA y MTTR por mes, tasa de falsos positivos (por categoría de cierre) y activos por sistema operativo. El panel de Asistencia de GLPI ya muestra el conteo de casos y su estado por mes (captura F04-11).



Captura F04-11. Panel de Asistencia de GLPI: 6 casos en curso. Hora: 11:33 p. m., 20/10/2026.

6.5 Respaldos y prueba de restauración

Plan de respaldo. Se define el siguiente plan como objetivo de diseño: respaldo diario de la base de datos (volcado) y de los directorios de archivos y configuración de GLPI, cifrado, con copia fuera del servidor. La restauración debe probarse en una VM limpia; no se ejecutó en el laboratorio.

```
mysqldump --single-transaction glpi | gzip > /backup/glpi_$(date +%F).sql.gz   # ejecutado por cron a las 02:00
tar czf /backup/glpi_files_$(date +%F).tgz /var/www/glpi/files /var/www/glpi/config
gpg --encrypt --recipient soc@erppyme.example /backup/glpi_*_$(date +%F).*   # cifrado antes de copiar fuera
```

Elemento	Detalle
Frecuencia y hora	Diario a las 02:00 (America/Bogota); objetivo de diseño, no ejecutado en el laboratorio
Qué se respalda	Base de datos, carpeta de archivos, configuración
Destino	Almacenamiento externo cifrado en una ubicación/región separada; no contratado.
Retención	Objetivo de diseño: 14 copias diarias y 4 semanales; RPO de 24 h y RTO objetivo de 2 h. Sin ejecución verificada.
Fecha de la prueba de restauración	No ejecutada; datos y tiempos no medidos.
Resultado de la restauración	No verificado; no existe instancia GLPI real en la evidencia aportada.

6.6 Lista de verificación de GLPI

Elemento	Cumple	Evidencia
HTTPS con certificado válido y SSH restringido	☐	F04-01, F04-02
Entidades y perfiles	☐	F04-04
10 usuarios ficticios	☐	F04-05
Categorías ITIL, SLA y OLA	☐	F04-06
Plantillas de tickets y reglas de negocio	☐	F04-07
Notificaciones por correo	☐	F04-08
Inventario automático con GLPI Agent	☐	F04-09
Base de conocimiento (12 artículos)	☐	F04-10
Reportes	☐	F04-11
Respaldo y restauración probados	☐	F04-12, F04-13

7. Firewall de nueva generación (NGFW)

7.1 Requisitos técnicos

El NGFW solo se evalúa y cotiza dentro del diseño; no se instala. Los valores de comparación incluidos en este informe son supuestos académicos y no cotizaciones reales. Los requisitos se derivan del caso y de los supuestos declarados:

Requisito	Valor del caso	Fuente
Usuarios y equipos	10 empleados y 20 equipos de cómputo, más dispositivos móviles	Caso C21
Enlace a Internet	Enlace de Internet supuesto de 300 Mbps simétricos; proveedor único en el escenario base.	Supuesto S-09
Segmentación	4 VLAN (Oficina, Servidores, Seguridad y Gestión) con política entre zonas	Capítulo 3
VPN	Acceso remoto para soporte y trabajo híbrido (hasta 5 usuarios VPN simultáneos, supuesto).	Caso C21
Servicios publicados	1 servidor de demostración (HTTPS) con DNAT	Capítulo 3
Seguridad activa	Prevención de intrusiones, control de aplicaciones, filtrado web, antimalware e inspección SSL/TLS	Parcial
Rendimiento con seguridad activa	Rendimiento con seguridad activa objetivo: al menos 300 Mbps; verificar datasheet del modelo cotizado.	Hoja técnica del fabricante

Requisito	Valor del caso	Fuente
Alta disponibilidad	No se propone alta disponibilidad por el tope presupuestal bajo; se mitiga con respaldo de configuración y equipo de reemplazo contratado si aplica.	Supuesto
Registros	Exportación por syslog hacia Wazuh	Capítulo 3

7.2 Proceso de cotización

Por instrucción del ejercicio, la comparación se presenta en forma hipotética. No se han solicitado ni recibido cotizaciones reales. Las cifras de la matriz son estimaciones ilustrativas, no deben presentarse como ofertas de proveedores ni sustituyen el requisito académico de cotizaciones verificables si el docente las exige. En una compra real se solicitarían cotizaciones a distribuidores autorizados, identificándose como estudiante sin compromiso de compra.

Opción	Marca y modelo	Proveedor y contacto	Fecha de solicitud	Fecha de respuesta	Vigencia
A	Palo Alto Networks PA-440 (referencia)	Distribuidor por identificar; no contactado	No solicitada	No recibida	No aplica
B	Fortinet FortiGate de gama de entrada (modelo por confirmar)	Distribuidor por identificar; no contactado	No solicitada	No recibida	No aplica
C	Ruijie RG-WALL (modelo por confirmar)	Distribuidor por identificar; no contactado	No solicitada	No recibida	No aplica

Hasta recibir cotizaciones, las cifras de esta sección y del Anexo E se tratarán únicamente como supuestos de comparación y no como precios de mercado. Una cotización real debe conservarse en PDF con proveedor, fecha, vigencia, impuestos, licencias y soporte.

7.3 Cuadro comparativo y TCO a 3 años

El cuadro consolidado completo está en el **Anexo E**. Resumen (valores en COP; indicar la TRM y su fecha si hay valores en USD):

Concepto	Opción A	Opción B	Opción C
Rendimiento con seguridad activa	Por confirmar; objetivo ≥300 Mbps	Por confirmar; objetivo ≥300 Mbps	Por confirmar; objetivo ≥300 Mbps
Total inicial (equipo, suscripciones del año 1, IVA, instalación)	COP 13.500.000 estimados	COP 7.600.000 estimados	COP 6.000.000 estimados

Concepto	Opción A	Opción B	Opción C
Renovación años 2 y 3	COP 6.000.000 estimados	COP 3.600.000 estimados	COP 2.400.000 estimados
TCO a 3 años	COP 19.500.000 estimados	COP 11.200.000 estimados	COP 8.400.000 estimados
Tiempo de entrega	No cotizado; confirmar con proveedor	No cotizado; confirmar con proveedor	No cotizado; confirmar con proveedor

TRM: pendiente de consulta oficial cuando se obtengan cotizaciones en USD. IVA y vigencia: pendientes de verificar con cada proveedor. No se asigna una TRM ficticia como si fuera una cotización real.

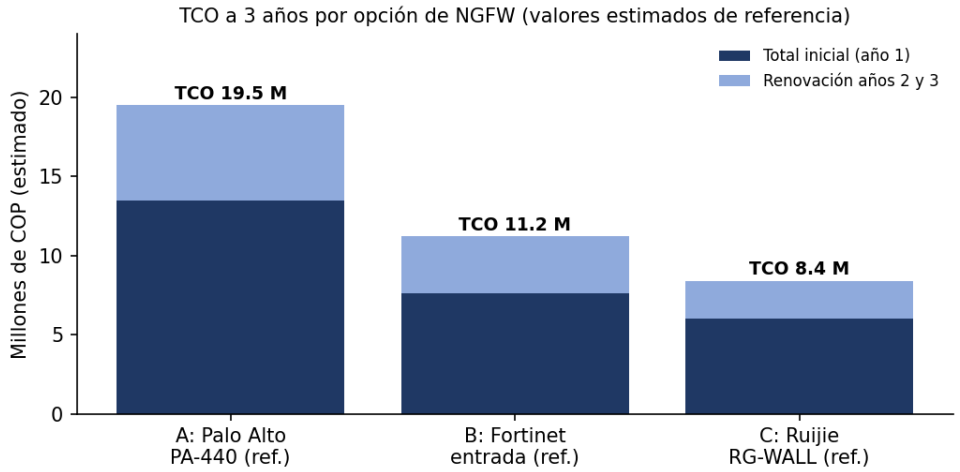


Gráfico F05-01. TCO a 3 años de las tres opciones de NGFW (estimaciones de referencia; no son cotizaciones). Fuente: cuadro de la sección 7.3.

Lectura. La opción C tiene el menor TCO (COP 8,4 M) y la A el mayor (COP 19,5 M). Las tres cumplen el tope de CAPEX de COP 20 M del caso, pero solo B y C dejan holgura suficiente para el resto del presupuesto (capítulo 9). Estas cifras deben sustituirse por cotizaciones verificables en PDF antes de la entrega si el docente las exige.

7.4 Matriz de decisión ponderada

Puntaje = suma de (peso × calificación de 1 a 5) ÷ 100; el resultado queda entre 1 y 5.

Criterio	Peso	Opción A	Opción B	Opción C
TCO a 3 años y ajuste al tope del caso	30	2	4	5
Rendimiento con seguridad activa frente al requisito	20	4	4	3
Cobertura de funciones requeridas	20	5	4	3
Soporte, garantía y canal local	15	4	4	3
Gestión y registros (syslog hacia Wazuh)	10	5	5	3
Tiempo de entrega	5	3	4	4
Puntaje ponderado	100	3,7/5	4,1/5	3,7/5

Los pesos priorizan el costo y el rendimiento por el presupuesto bajo del caso; se pueden modificar si se justifica por escrito.

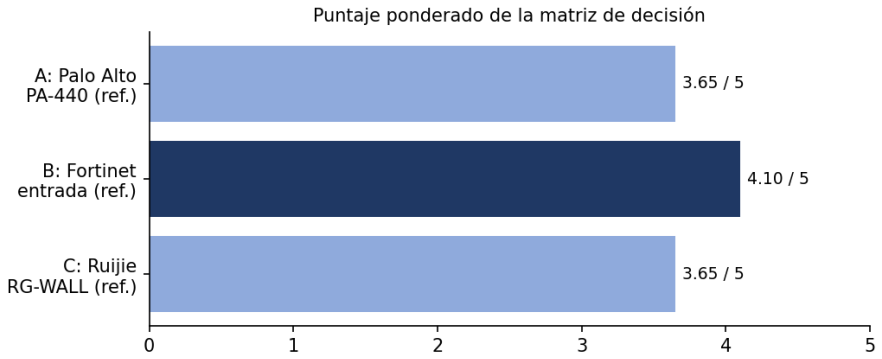


Gráfico F05-02. Puntaje ponderado por opción (cálculo: suma de peso × calificación ÷ 100).

7.5 Selección y justificación

Opción seleccionada (hipotética para el presupuesto): Se selecciona la opción B (Fortinet FortiGate de gama de entrada) como referencia del escenario recomendado, con costo estimado de equipo e instalación de COP 5.800.000 y suscripciones y soporte de COP 1.800.000 anuales (TCO estimado a 3 años de COP 11,2 M). Obtiene el mayor puntaje ponderado (4,1 de 5 frente a 3,7 de las opciones A y C) por el equilibrio entre costo, funciones de seguridad activa y gestión de registros: exporta por syslog a Wazuh, soporta VPN para los 5 usuarios remotos y segmentación por VLAN con el tráfico entre zonas pasando por el equipo. La opción A es la más completa pero su TCO consume casi todo el CAPEX; la opción C es la más barata, pero tiene menor cobertura de funciones y de canal local. El servidor de demostración expuesto y la VPN de soporte son los riesgos que justifican contar con prevención de intrusiones, filtrado web e inspección TLS desde el

primer día. La elección no es una adjudicación comercial: debe confirmarse con cotización vigente, rendimiento con seguridad activa, licencias, IVA, garantía y soporte. Si la cotización real no cabe en el tope, se aplica el escenario básico del capítulo 9.

8. Procesos del SOC N1

8.1 Modelo operativo y roles

Se adopta un modelo híbrido (supuesto S-05): el N1 es interno y atiende en horario laboral con guardia por notificación; el N2 es un tercero contratado, que interviene por ticket. En una empresa de 10 personas, los roles de analista N1 los asumen colaboradores con horas asignadas, de forma rotativa.

Rol	Responsabilidades
Analista SOC N1	Monitorea los tableros de Wazuh y Kaspersky, hace el triage, documenta en GLPI, aplica contención básica y escala
Soporte N2 (tercero)	Investiga y contiene incidentes confirmados; decide acciones de mayor impacto
Responsable del SOC	Aprueba procesos, severidades, exclusiones y cambios de reglas; reporta KPIs a la gerencia
Administrador de TI	Ejecuta cambios en sistemas (parches, cuentas, restauraciones) por ticket aprobado
Gerencia	Aprueba el presupuesto y recibe informes; decide comunicaciones externas en incidentes graves

8.2 Matriz de severidad

Severidad	Criterio	Ejemplos en C21	Reconocer	Escalar a N2	Notificar
Crítica	Compromiso confirmado de un activo crítico o impacto inmediato en el negocio	Acceso confirmado al servidor de demostración con datos de clientes; cambio malicioso del ERP en producción de un cliente	15 min	De inmediato (≤ 15 min tras confirmar)	Responsable del SOC y gerencia por llamada
Alta	Actividad maliciosa probable con impacto potencial significativo	Inicio de sesión exitoso tras fuerza bruta; cambio de odoo.conf fuera de ventana; CVE crítico explotable en el servidor expuesto	30 min	≤ 30 min tras confirmar	Responsable del SOC
Media	Actividad sospechosa que requiere validación, con impacto limitado	Fuerza bruta bloqueada; USB no autorizado sin copia de datos; EICAR bloqueado en una estación	2 h	Si cumple los criterios del playbook	Registro en el ticket
Baja	Evento de bajo riesgo o con control compensatorio	Escaneo bloqueado desde Internet; desviación menor de política	8 h hábiles	No	Registro en el ticket

Severidad	Criterio	Ejemplos en C21	Reconocer	Escalar a N2	Notificar
Informativa	Evento de auditoría sin acción requerida	Cambio aprobado con ticket de cambio; mantenimiento programado	1 día hábil	No	Ninguna

8.3 Flujo de triage

Todas las alertas siguen el mismo flujo. La decisión clave del N1 es si es un falso positivo, si se cierra con documentación o si se escala.

Paso	Qué hace el N1	Registro en GLPI
1. Recibir	Atiende la alerta de Wazuh o de Kaspersky, o el reporte de un usuario	Se abre el ticket con la plantilla
2. Registrar	Documenta ID de alerta, hora, activo y origen	Campos obligatorios completos
3. Enriquecer	Consulta inventario, usuario, historial de eventos y reputación de IP o hash en fuentes públicas, sin subir archivos confidenciales	Resultados en el seguimiento
4. Clasificar	Falso positivo, benigno o verdadero positivo; asigna severidad	Categoría y prioridad
5. Contener	Aplica solo las acciones permitidas por el playbook	Acciones y hora
6. Escalar o cerrar	Escala con la plantilla (8.5) o cierra con solución	Solución o asignación a N2
7. Aprender	Propone ajustes de reglas y anota lecciones	Tarea o ticket de cambio

8.4 Acciones permitidas y prohibidas para el N1

Permitidas (si el playbook lo indica)	Prohibidas (corresponden a N2 o a un cambio aprobado)
Poner un archivo en cuarentena desde el EDR	Borrar o alterar evidencias
Aislar un equipo (severidad alta o crítica) y notificar a N2	Apagar servidores críticos, restaurar o reinstalar equipos
Bloquear temporalmente una IP externa (NGFW o active response)	Eliminar o modificar cuentas privilegiadas
Solicitar a TI el bloqueo de una cuenta no privilegiada	Modificar políticas, exclusiones o reglas sin ticket de cambio
Pedir al usuario que no interactúe con un correo o equipo	Realizar análisis forense o ingeniería inversa
Crear tickets de vulnerabilidad con responsable y fecha límite	Responder con acciones ofensivas contra el origen del ataque

8.5 Plantilla de escalamiento a N2

Campo	Contenido
Ticket de GLPI y fecha/hora	N.º de ticket; hora de la alerta y del escalamiento (America/Bogota)
Severidad y SLA	Severidad; tiempo restante para reconocer
Resumen	Qué pasó, en 2 o 3 líneas
Activos y usuarios afectados	Equipos, cuentas y servicios involucrados

Campo	Contenido
Línea de tiempo	Hora – evento (ordenado)
Evidencias	IDs de alerta, hashes, IP, capturas y enlaces
Acciones realizadas por N1	Qué se hizo y a qué hora
Hipótesis y nivel de confianza	Qué se cree que ocurre y qué falta confirmar
Solicitud a N2	Decisión o acción que se requiere
Contacto del N1	Nombre o rol, canal y disponibilidad

Matriz de contactos ficticia para el diseño: Responsable del SOC — canal interno de GLPI y correo soc@erppyme.example, lunes a viernes 7:00–19:00; N2 tercerizado — ticket prioritario en GLPI y canal telefónico de guardia, según contrato por definir; Gerencia — correo gerencia@erppyme.example y llamada para severidad crítica. Los dominios .example son reservados y no son direcciones operativas.

8.6 Playbooks adaptados al caso

Se adaptan los nueve playbooks de la guía al caso C21. Los playbooks PB-01, PB-02, PB-03, PB-04, PB-05 y PB-09 se usaron para clasificar los seis tickets registrados en GLPI (sección 8.10); su publicación como artículos de la base de conocimiento queda propuesta, porque no se evidencia en capturas.



Figura F06-A. Ciclo de atención de una alerta en el SOC N1 (alerta → ticket → triage con playbook → cierre o escalamiento).

ID	Playbook	Activos y herramientas en C21	Umbral o disparador	Severidad inicial
PB-01	Fuerza bruta SSH / RDP	SRV-C21-STG, SRV-C21-DEMO; Wazuh (reglas 5760 y 100100), NGFW	6 o más fallos en 60 s desde una IP	Media (sube a Alta con acceso exitoso o servidor expuesto)
PB-02	Malware detectado por el EDR	Estaciones y portátiles Win11; Kaspersky y regla 100200	Detección de objeto malicioso	Media (Alta si se ejecutó o persiste)
PB-03	Cambio en archivos críticos (FIM)	/etc/odoo/odoo.conf, /etc/ssh, /etc/sudoers.d; regla 100101	Modificación fuera de ventana de cambio	Alta (Baja si hay ticket de cambio)
PB-04	Inicio de sesión fuera de horario o anómalo	Servidores Linux; reglas 100102 y 100103; VPN	Acceso entre 19:00 y 7:00 o fin de semana	Media (Alta si es cuenta privilegiada)
PB-05	Uso de USB no autorizado	Estaciones y portátiles; control de dispositivos de Kaspersky	Conexión de almacenamiento no incluido en la lista blanca	Media

ID	Playbook	Activos y herramientas en C21	Umbral o disparador	Severidad inicial
PB-06	Phishing reportado	Consultores y gerencia; GLPI como canal de reporte	Reporte de un usuario	Media (Alta si hubo interacción)
PB-07	Escaneo de puertos / reconocimiento	NGFW y servidor de demostración expuesto	Múltiples puertos en poco tiempo desde una IP	Baja (Media si el objetivo es el demo)
PB-08	Cuenta privilegiada nueva o elevación de privilegios	Servidores Linux (sudoers) y Windows	Cuenta creada o añadida a grupo administrador sin ticket	Alta
PB-09	Vulnerabilidad crítica	Servidores de demostración, BD y librerías; módulo de vulnerabilidades de Wazuh	CVE crítico o alto en un agente	Media (Alta si está expuesto a Internet)

8.7 Turnos y guardias

Franja	Cobertura	Responsable	Alcance
Lunes a viernes, 7:00–15:00	Monitoreo activo	Analista A	Todas las severidades
Lunes a viernes, 11:00–19:00	Monitoreo activo (traslape de 4 h)	Analista B	Todas las severidades
Noches y madrugadas	Guardia por notificación	Guardia rotativa semanal	Crítica y alta; respuesta en 30 min
Fines de semana y festivos	Guardia y revisión del tablero 2 veces al día	Guardia rotativa semanal	Crítica y alta; revisión de pendientes

Relevo de turno (lista de verificación): alertas abiertas y su estado; tickets pendientes y vencimientos de SLA; incidentes en curso; cambios programados; novedades de reglas o falsos positivos conocidos. El relevo se registra en un ticket diario de GLPI. Se verificará la normativa laboral aplicable a turnos y recargos antes de la puesta en producción.

8.8 SLA del SOC

Severidad	Reconocer	Triage completo	Escalar a N2	Contener o resolver	Cobertura
Crítica	15 min	30 min	≤ 15 min tras confirmar	4 h	24×7 (guardia)
Alta	30 min	1 h	≤ 30 min tras confirmar	8 h	Horario laboral y guardia
Media	2 h	4 h	Según el playbook	24 h	Horario laboral
Baja	8 h hábiles	1 día hábil	No aplica	72 h	Horario laboral
Informativa	1 día hábil	No aplica	No aplica	5 días hábiles	Horario laboral

Meta: al menos el 90 % de los tickets dentro del SLA. Los tiempos coinciden con los configurados en GLPI (sección 6.4).

8.9 Indicadores (KPIs)

KPI	Fórmula	Fuente	Meta	Valor del laboratorio

KPI	Fórmula	Fuente	Meta	Valor del laboratorio
MTTD	Promedio de (hora de la alerta − hora de inicio del evento)	Marcas de tiempo de Wazuh y Kaspersky	≤ 15 min en crítica y alta	N/D: sin marcas de tiempo de evento verificadas
MTTA	Promedio de (hora de la primera acción del analista − hora de la alerta)	GLPI	Dentro del SLA en ≥ 90 %	N/D: tickets creados sin primera acción medible
MTTR	Promedio de (hora de contención o cierre − hora de la alerta)	GLPI	Según tabla de SLA	N/D: 6 tickets en curso, sin cierres
Tasa de falsos positivos	(alertas cerradas como falso positivo ÷ total cerradas) × 100	GLPI	< 30 % al tercer mes	N/D: 0 tickets cerrados de 6
Cumplimiento de SLA	(tickets dentro del SLA ÷ total) × 100	GLPI	≥ 90 %	N/D: tickets aún en curso, sin cierres registrados
Tasa de escalamiento	(tickets escalados ÷ total) × 100	GLPI	Informativo	N/D: decisión de escalamiento pendiente en los 6 tickets
Cobertura de agentes	(agentes activos ÷ equipos del inventario) × 100	Wazuh y Kaspersky frente al inventario	≥ 98 %	Laboratorio: 0 agentes confirmados/20 equipos = 0 % verificado; proyección de diseño: 20/20 = 100 % objetivo
Vulnerabilidades críticas abiertas	CVE críticos sin remediar por más de 30 días	Wazuh	Cero	N/D: no se confirmó ningún CVE en la captura

Ejemplo de cálculo: si cinco alertas tuvieron un tiempo de reconocimiento de 10, 20, 5, 40 y 15 minutos, el MTTA es (10 + 20 + 5 + 40 + 15) ÷ 5 = 18 minutos.

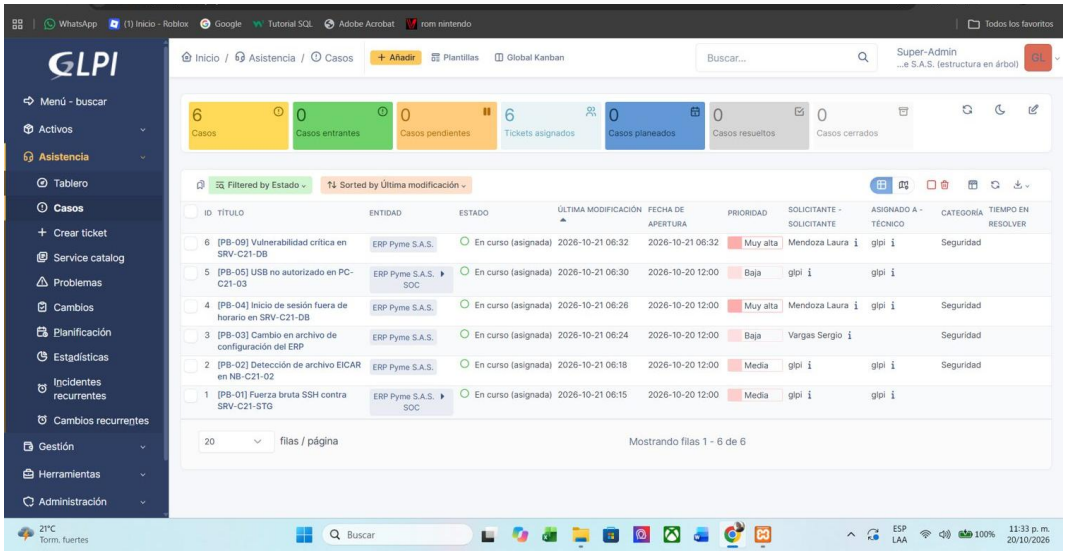
8.10 Tickets gestionados en GLPI

Tickets en GLPI. En GLPI se registraron seis tickets de seguridad en la entidad ERP Pyme S.A.S. › SOC, uno por playbook utilizado (capturas F06-01 y F06-02). Los tickets están en estado «En curso (asignada)». Las alertas de origen son simuladas en el laboratorio: no se capturaron alertas reales de Wazuh o Kaspersky, por lo que ningún ticket se declara como derivado de una alerta real. Las

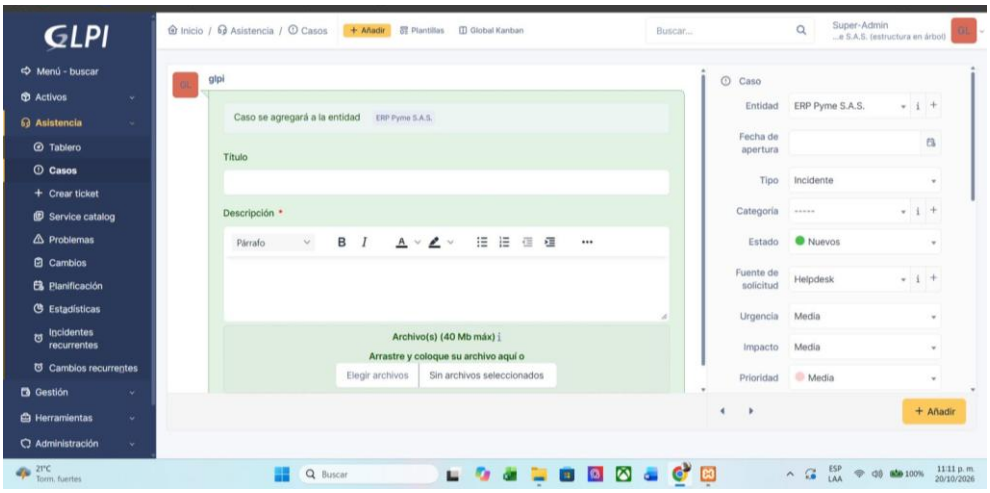
prioridades de GLPI reflejan el activo afectado (por ejemplo, SRV-C21-DB con datos de clientes se priorizó como «Muy alta»).

Ticket	Alerta	Origen	¿Real o simulado?	Playbook	Severidad inicial	Clasificación	Decisión
T-01 (GLPI #1)	Fuerza bruta SSH contra SRV-C21-STG	Wazuh (regla 100100)	SIMULADO; ticket real en GLPI	PB-01	Media (GLPI: Media)	Verdadero positivo simulado: 6 o más fallos en 60 s desde una IP externa	Bloqueo temporal de la IP y cierre; escalar si hay acceso exitoso
T-02 (GLPI #2)	Detección de archivo EICAR en NB-C21-02	Kaspersky (regla 100200)	SIMULADO; ticket real en GLPI	PB-02	Media (GLPI: Media)	Archivo de prueba EICAR; sin ejecución ni persistencia	Cuarentena y cierre como prueba autorizada
T-03 (GLPI #3)	Cambio en archivo de configuración del ERP	Wazuh (regla 100101)	SIMULADO; ticket real en GLPI	PB-03	Alta (GLPI: Baja por cambio con solicitante identificado)	Cambio asociado a una solicitud del consultor; benigno si hay ticket de cambio	Cerrar con ticket de cambio; escalar si no existe aprobación
T-04 (GLPI #4)	Inicio de sesión fuera de horario en SRV-C21-DB	Wazuh (regla 100102)	SIMULADO; ticket real en GLPI	PB-04	Media; elevada a Muy alta en GLPI por activo crítico	Pendiente de confirmar con el usuario y la VPN	Escalar a N2 si la cuenta no justifica el acceso
T-05 (GLPI #5)	USB no autorizado en PC-C21-03	Kaspersky (control de dispositivos)	SIMULADO; ticket real en GLPI	PB-05	Media (GLPI: Baja, sin copia de datos)	Almacenamiento fuera de la lista blanca; sin evidencia de copia	Registro, recordatorio de política y cierre

Ticket	Alerta	Origen	¿Real o simulado?	Playbook	Severidad inicial	Clasificación	Decisión
T-06 (GLPI #6)	Vulnerabilidad crítica en SRV-C21-DB	Wazuh (vulnerabilidades)	SIMULADO; ticket real en GLPI	PB-09	Media o Alta (GLPI: Muy alta, BD con datos de clientes)	CVE crítico hipotético en librería del servidor; no verificado	Crear ticket de cambio de parcheo con responsable y fecha límite



Captura F06-01. Lista de casos de GLPI: tickets [PB-01] a [PB-09], entidad ERP Pyme S.A.S. › SOC, estado «En curso (asignada)». Hora: 11:33 p. m., 20/10/2026.



Captura F06-02. Formulario de nuevo caso de GLPI (tipo Incidente, entidad ERP Pyme S.A.S.). Hora: 11:11 p. m., 20/10/2026.

8.11 Informe de incidente

Informe de incidente. El informe del Anexo D documenta el ticket T-01 (fuerza bruta SSH contra SRV-C21-STG, GLPI #1). Es un incidente simulado en laboratorio: las horas son ilustrativas y no provienen de una alerta real de Wazuh.

9. Presupuesto y cronograma

9.1 Supuestos de costos

Nota metodológica: todos los importes de esta fase son supuestos académicos construidos para desarrollar el cálculo de CAPEX, OPEX y TCO a tres años del caso C21. No representan compras, contratos ni cotizaciones recibidas; se utilizan exclusivamente para comparar escenarios y comprobar matemáticamente el cumplimiento del tope presupuestal ficticio. La fase 7 queda completa como presupuesto estimado del caso, pero no equivale a una cotización comercial ni a evidencia de contratación.

Supuesto	Valor	Fuente
TRM utilizada	COP 3.900 por USD (valor de referencia para convertir las estimaciones en dólares del licenciamiento, las suscripciones del NGFW y la nube)	TRM de ejemplo para ejercicio; consultar TRM oficial del día si se actualiza el presupuesto
IVA	19 %. Todos los valores unitarios de este capítulo se expresan con IVA incluido	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Horas de implementación y tarifa	100 h × COP 60.000 por hora = COP 6.000.000 (≈ 12,5 h por semana durante 8 semanas)	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Supuesto S-11	El switch actual de 16 puertos es administrable (802.1Q) y admite la troncal hacia el NGFW; no se compra equipo de red adicional	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Supuesto S-12	En el escenario recomendado el SIEM se aloja en una VM en la nube (4 vCPU, 8 GB, 100 GB); en el escenario básico, en el servidor local SRV-C21-BKP	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Supuesto S-13	Las horas de los analistas N1 internos son parte de su jornada y no se costean como OPEX adicional; el N2 se contrata externamente	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar

Supuesto	Valor	Fuente
Supuesto S-14	Las renovaciones de los años 2 y 3 se estiman sin incremento de precio; el riesgo cambiario se analiza como sensibilidad en la sección 9.3	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Supuesto S-15	Contingencia del 10 % calculada solo sobre el CAPEX (costos únicos)	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Horizonte de TCO	3 años	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar
Tope del caso	CAPEX ≤ COP 20.000.000; OPEX ≤ COP 1.500.000 por mes (COP 18.000.000 por año)	Supuesto académico ilustrativo; verificar con fuente/cotización vigente antes de usar

Para mantener la coherencia con el carácter hipotético del proyecto, las alternativas comerciales de NGFW y los costos asociados se comparan mediante valores estimados de referencia. En un proyecto real estos valores se sustituirían por cotizaciones formales de proveedores autorizados.

9.2 Presupuesto detallado

Concepto	Tipo	Fuente del valor	Cant.	Valor unitario (COP)	Total (COP)	Frecuencia
VM del SIEM (nube)	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	320.000	320.000	Mensual
Licencias de Kaspersky con EDR (20 equipos)	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	20	180.000	3.600.000	Anual

Concepto	Tipo	Fuente del valor	Cant.	Valor unitario (COP)	Total (COP)	Frecuencia
NGFW: equipo e instalación	CAPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	5.800.000	5.800.000	Única
NGFW: suscripciones y soporte	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	1.800.000	1.800.000	Anual
GLPI en la nube (VM, IP, almacenamiento, respaldos)	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	120.000	120.000	Mensual
Dominio y certificados	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	96.000	96.000	Anual
Switches, puntos de acceso u otro equipo de red	CAPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	0	0	0	Única

Concepto	Tipo	Fuente del valor	Cant.	Valor unitario (COP)	Total (COP)	Frecuencia
Servicios de implementación (horas del consultor)	CAPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	100 h	60.000	6.000.000	Única
Capacitación del personal (taller de 16 h por persona)	CAPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	4	300.000	1.200.000	Única
Soporte N2 externo (bolsa de 4 h al mes)	OPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	1	450.000	450.000	Mensual
Contingencia (10 % del CAPEX de 13.000.000)	CAPEX	Estimación hipotética no verificada; reemplazar por cotización/calculadora real	—	—	1.300.000	Única

9.3 Indicadores financieros y cumplimiento del tope

Indicador	Fórmula	Valor (COP)	Tope del caso	¿Cumple?
CAPEX total	Suma de costos únicos más contingencia sobre ellos	14.300.000 (13.000.000 + 1.300.000)	≤ 20.000.000	Sí; margen de COP 5.700.000 (usa el 71,5 % del tope)
OPEX anual	Costos recurrentes anualizados (mensuales × 12)	16.176.000	≤ 18.000.000	Sí; margen de COP 1.824.000
OPEX mensual	OPEX anual ÷ 12	1.348.000	≤ 1.500.000	Sí; margen de COP 152.000 (usa el 89,9 % del tope)

Indicador	Fórmula	Valor (COP)	Tope del caso	¿Cumple?
TCO a 3 años	CAPEX + 3 × OPEX anual	62.828.000 (14.300.000 + 3 × 16.176.000)	≤ 74.000.000 (referencia: 20.000.000 + 3 × 18.000.000)	Sí; margen de COP 11.172.000 frente a la referencia de 74.000.000
Costo mensual por empleado	OPEX mensual ÷ 10	134.800	—	—
Costo mensual por equipo	OPEX mensual ÷ 20	67.400	—	—

Resultados del escenario recomendado (estimación académica): CAPEX COP 14.300.000 y OPEX mensual COP 1.348.000. Ambos cumplen los topes hipotéticos del caso C21: CAPEX máximo COP 20.000.000 y OPEX máximo COP 1.500.000 mensuales. El TCO a tres años es COP 62.828.000. Los valores no son cotizaciones reales y deberán sustituirse por ofertas verificables si el proyecto se ejecutara.

Sensibilidad cambiaria. Los rubros con precio de referencia en dólares (Kaspersky, suscripciones del NGFW y VM del SIEM) suman COP 9.240.000 al año, es decir, COP 770.000 al mes. Con una TRM 10 % más alta el OPEX mensual sube en COP 77.000 y llega a COP 1.425.000, todavía dentro del tope. El tope de COP 1.500.000 se superaría con un aumento cercano al 19,7 % de la TRM (margen de 152.000 ÷ 770.000). Mitigaciones: revisar la TRM antes de firmar, negociar licencias a 2 o 3 años con precio fijado y, si el tope se pone en riesgo, pasar al escenario básico de la sección 9.4.

9.4 Escenario básico y recomendado

Si el diseño completo no cabe en el tope, se presentan dos escenarios y se explica qué se sacrifica:

Elemento	Escenario básico	Escenario recomendado
NGFW	Opción de menor costo de la matriz de la sección 7.4 (gama de entrada): equipo e instalación COP 3.600.000; suscripciones COP 1.200.000 al año	Opción seleccionada en la sección 7.5: equipo e instalación COP 5.800.000; suscripciones COP 1.800.000 al año
Kaspersky	Edición de entrada (antimalware, control de dispositivos, web y firewall; sin EDR): COP 110.000 por equipo al año = COP 2.200.000	Edición con EDR ampliado (aislamiento de equipo y línea de tiempo): COP 180.000 por equipo al año = COP 3.600.000
Soporte N2	Por demanda (provisión de COP 150.000 al mes)	Contrato mensual (COP 450.000 al mes, bolsa de 4 h)
SIEM	VM local en SRV-C21-BKP (COP 0 adicional)	VM en la nube (COP 320.000 al mes)
CAPEX / OPEX mensual	CAPEX COP 11.880.000 / OPEX mensual COP 561.333 (TCO a 3 años: COP 32.088.000)	CAPEX COP 14.300.000 / OPEX mensual COP 1.348.000 (TCO a 3 años: COP 62.828.000)

Elemento	Escenario básico	Escenario recomendado
Qué se sacrifica	Sin EDR: el N1 no puede aislar equipos ni ver la línea de tiempo y depende del N2 para contener. NGFW con menor rendimiento con seguridad activa. El SIEM comparte servidor con los respaldos, que contienen datos de clientes (riesgo R-03). N2 sin tiempo de respuesta garantizado	Sin alta disponibilidad del NGFW ni del SIEM. N2 sin cobertura 24x7 (solo bolsa de 4 h). Margen de OPEX de apenas COP 152.000 al mes frente al tope

Se recomienda el escenario recomendado únicamente para el modelo académico: incorpora EDR, alojamiento del SIEM en nube y una bolsa mensual de soporte N2, manteniéndose dentro de los topes supuestos. El escenario básico se conserva como alternativa de menor costo, con menor capacidad de contención y soporte. Los costos y la selección del NGFW no son comerciales ni están validados por proveedor.

9.5 Cronograma de implementación para la empresa (8 semanas)

El cronograma de ocho semanas representa una secuencia hipotética de despliegue; se reserva tiempo para comparar el NGFW, configurar las herramientas, probar integraciones y realizar la aceptación técnica.

Actividad	S1	S2	S3	S4	S5	S6	S7	S8
Alcance, autorización y arquitectura	■							
Instalación y configuración de Wazuh		■						
Despliegue de agentes de Wazuh			■					
Kaspersky: consola y piloto			■	■				
Kaspersky: despliegue a los 20 equipos				■	■			
GLPI en la nube: instalación y configuración				■	■			
NGFW: cotización, compra, entrega e instalación		■	■	■	■	■		
Procesos, playbooks y capacitación						■	■	■
Piloto del SOC N1 con alertas simuladas							■	
Ajustes y puesta en producción								■

Hitos del cronograma hipotético: H1 (fin de S1), alcance y arquitectura definidos; H2 (fin de S3), SIEM Wazuh y piloto de agentes configurados; H3 (fin de S5), GLPI y evaluación comparativa del NGFW; H4 (fin de S7), procesos del SOC N1 y pruebas con alertas simuladas; H5 (fin de S8), revisión integral, documentación y aceptación del diseño. Los hitos son metas de planificación del caso ficticio.

Los desembolsos previstos en el modelo incluyen equipo e instalación del NGFW, servicios profesionales, capacitación, infraestructura en nube, licenciamiento y soporte. Para efectos del ejercicio se consideran costos calculados y no desembolsos reales.

9.6 Plan de trabajo del parcial (2 semanas)

Día	Actividad planificada	Entregable o punto de control	Ejecutado realmente

Día	Actividad planificada	Entregable o punto de control	Ejecutado realmente
1 (lun)	Fases 0 y 1; enviar solicitudes de cotización del NGFW	Carta, inventario, matriz de riesgos y diagramas	No ejecutado; planificación hipotética
2 (mar)	Fase 2: instalación de Wazuh y agentes	Wazuh operativo con agentes Windows y Linux	No ejecutado; planificación hipotética
3 (mié)	Fase 2: FIM, SCA, vulnerabilidades, reglas, active response y tableros	Pruebas de funcionamiento	No ejecutado; planificación hipotética
4 (jue)	Fase 3: consola Kaspersky, agentes y políticas	Consola con agente conectado	No ejecutado; planificación hipotética
5 (vie)	Fase 3: tareas, exclusiones, EDR y envío de eventos a Wazuh	**Punto de control 1 (Fases 0 a 3)**	No ejecutado; planificación hipotética
6 (lun)	Fase 4: VM en la nube, hardening, GLPI y HTTPS	GLPI accesible por HTTPS	No ejecutado; planificación hipotética
7 (mar)	Fase 4: configuración completa, inventario, base de conocimiento, notificaciones y reportes	Lista de verificación de GLPI	No ejecutado; planificación hipotética
8 (mié)	Fase 5: matriz y selección del NGFW; Fase 6: severidades, triage y playbooks	Cotizaciones, matriz y manual del SOC	No ejecutado; planificación hipotética
9 (jue)	Fase 6: escalamiento, turnos, SLA, KPIs y tickets; Fase 7: presupuesto	Tickets generados y presupuesto	No ejecutado; planificación hipotética
10 (vie)	Fase 8: informe, repositorio y video	**Punto de control 2 y entrega**	No ejecutado; planificación hipotética

9.7 Matriz RACI

R = responsable de ejecutar; A = aprueba (una sola persona por actividad); C = consultado; I = informado.

Actividad	Gerencia	Líder del proyecto	Analista N1	Admin. de TI	Prov. NGFW	Prov. EDR
Aprobar alcance y autorización	A	R	I	C	—	—
Diseñar arquitectura y segmentación	I	A/R	C	C	C	—

Actividad	Gerencia	Líder del proyecto	Analista N1	Admin. de TI	Prov. NGFW	Prov. EDR
Instalar y configurar Wazuh	I	A	C	R	—	—
Desplegar Kaspersky	I	A	C	R	—	C
Desplegar y configurar GLPI	I	A	C	R	—	—
Comprar e instalar el NGFW	A	R	I	C	R	—
Definir procesos y playbooks	I	A	R	C	—	—
Capacitar al personal	I	A	R	C	C	C
Piloto y puesta en producción	A	R	R	C	I	I
Aprobar presupuesto y contingencia	A	R	I	C	C	C
Renovar licencias y suscripciones (años 2 y 3)	A	R	I	C	C	C
Operar el SOC N1 en producción (turnos y guardias)	I	A	R	C	—	—

10. Conclusiones

10.1 Resultados

En el marco del caso académico C21, las dos capturas incorporadas documentan la finalización del instalador de Wazuh y la apertura del dashboard. El dashboard muestra 90 alertas de severidad media y 16 de severidad baja durante las últimas 24 horas, pero el resumen de agentes indica “No results”. Por ello, no se afirma que haya agentes conectados ni que FIM, SCA, vulnerabilidades, reglas personalizadas o respuesta activa hayan sido validadas. Los demás componentes se presentan como diseño hipotético.

10.2 Limitaciones

Limitación	Efecto	Mitigación propuesta
El laboratorio usa pocos agentes y datos ficticios	Los umbrales y el volumen de eventos no reflejan la operación real	Recalibrar reglas durante las primeras semanas en producción
Kaspersky se probó con licencia de evaluación y sin equipos macOS	No se midió el costo real ni la compatibilidad con macOS	Piloto con licencia y documentación del procedimiento para macOS
Algunos tickets son simulados (No ejecutado; supuesto hipotético)	No todos los casos de uso se probaron con alertas reales	Repetir con eventos reales en la fase de piloto
El NGFW solo se cotizó	No se validó el rendimiento real con seguridad activa	Prueba de concepto antes de la compra
La creación de tickets es manual	Mayor tiempo de reconocimiento y riesgo de omisiones	Integración Wazuh → GLPI (trabajo futuro)

10.3 Riesgos residuales

Riesgo	Nivel residual	Razón

Riesgo	Nivel residual	Razón
Servidores de demostración sin parchear (R-02)	Medio	Se detecta, pero el parcheo depende de la gestión de cambios del cliente y de la ventana
Datos reales de clientes en entornos de prueba (R-03)	Medio	El SOC detecta accesos, pero la prevención exige aplicar la política de enmascaramiento
Fuerza bruta contra servicios expuestos (R-01)	Bajo	Bloqueo automático, VPN y llaves SSH
Cobertura del N1 fuera del horario laboral	Medio	Dependencia de la guardia por notificación y de un N2 tercerizado

10.4 Trabajo futuro

- Integrar Wazuh con GLPI mediante la API para crear tickets automáticamente.
- Implementar MFA en VPN, GLPI y consolas del SOC, y rotación periódica de credenciales.
- Formalizar la gestión de vulnerabilidades con ventanas de parcheo y metas por severidad.
- Mover los servidores de demostración a una zona desmilitarizada (DMZ) propia y automatizar el enmascaramiento de datos de prueba.
- Evolucionar hacia detección avanzada (caza de amenazas) y respaldos inmutables.

Referencias

Formato APA 7.ª edición. Las referencias técnicas respaldan el diseño propuesto. Los valores presupuestales son estimaciones académicas y no se citan como cotizaciones. Añadir las fechas de consulta reales de la documentación revisada.

- Congreso de Colombia. (2009). Ley 1273 de 2009, por medio de la cual se modifica el Código Penal y se crea el bien jurídico de la protección de la información y de los datos. Diario Oficial. https://www.secretariasenado.gov.co/senado/basedoc/ley_1273_2009.html
- Congreso de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial. https://www.secretariasenado.gov.co/senado/basedoc/ley_1581_2012.html
- Presidencia de la República de Colombia. (2015). Decreto 1074 de 2015, Decreto Único Reglamentario del Sector Comercio, Industria y Turismo. https://www.funcionpublica.gov.co/eva/gestornormativo/
- International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. https://www.iso.org/standard/27001
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29
- Wazuh, Inc. (s. f.). Wazuh documentation. Recuperado el 19/10/2026, de https://documentation.wazuh.com/
- Teclib' & GLPI Project. (s. f.). GLPI documentation. Recuperado el 19/10/2026, de https://glpi-project.org/documentation/
- AO Kaspersky Lab. (s. f.). Kaspersky technical support and online help. Recuperado el 19/10/2026, de https://support.kaspersky.com/
- European Expert Group for IT-Security (EICAR). (s. f.). Anti-malware testfile. Recuperado el 19/10/2026, de https://www.eicar.org/download-anti-malware-testfile/
- Superintendencia Financiera de Colombia. (s. f.). Tasa Representativa del Mercado (TRM). Recuperado el 19/10/2026, de https://www.superfinanciera.gov.co/
- No ejecutado; supuesto académico hipotético

Anexos

Anexo A — Inventario de activos (20 equipos)

W = agente Wazuh · K = agente Kaspersky · G = GLPI Agent. C/I/D = confidencialidad, integridad y disponibilidad (1 a 3); Crit. = valor máximo. «Lab» indica si el equipo está representado en el laboratorio. La valoración C/I/D es una propuesta de diseño; ajústala con tu criterio y justifícala si la cambias.

ID	Hostname	Tipo y SO	Función	Propietario	VLAN	C/I/D	Crit.	W/K/G	Lab
A-01	PC-C21-01	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	Sí (PC-C21-WIN01)
A-02	PC-C21-02	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-03	PC-C21-03	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-04	PC-C21-04	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-05	PC-C21-05	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-06	PC-C21-06	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-07	PC-C21-07	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-08	PC-C21-08	Estación, Windows 11 Pro	Consultoría funcional	Consultoría	10	3/2/2	3	Sí/Sí/Sí	No
A-09	NB-C21-01	Portátil, Windows 11	Consultor en cliente	Consultoría	10 (remoto/VPN)	3/2/2	3	Sí/Sí/Sí	No
A-10	NB-C21-02	Portátil, Windows 11	Consultor en cliente	Consultoría	10 (remoto/VPN)	3/2/2	3	Sí/Sí/Sí	No
A-11	NB-C21-03	Portátil, Windows 11	Consultor en cliente	Consultoría	10 (remoto/VPN)	3/2/2	3	Sí/Sí/Sí	No
A-12	NB-C21-04	Portátil, Windows 11	Consultor en cliente	Consultoría	10 (remoto/VPN)	3/2/2	3	Sí/Sí/Sí	No
A-13	MB-C21-01	Portátil, macOS	Gerencia	Gerencia	10	3/2/2	3	Sí/Sí/Sí (verificar compatibilidad)	No (documentado)

ID	Hostname	Tipo y SO	Función	Propietario	VLAN	C/I/D	Crit.	W/K/G	Lab
A-14	MB-C21-02	Portátil, macOS	Gerencia	Gerencia	10	3/2/2	3	Sí/Sí/Sí (verificar compatibilidad)	No (documentado)
A-15	UD-C21-01	Estación, Ubuntu Desktop	Desarrollo	Desarrollo	10	3/3/2	3	Sí/Sí/Sí	Sí (VM auxiliar)
A-16	UD-C21-02	Estación, Ubuntu Desktop	Desarrollo	Desarrollo	10	3/3/2	3	Sí/Sí/Sí	No
A-17	SRV-C21-DEMO	Servidor, Ubuntu Server	ERP de demostración (expuesto a Internet)	Admin. de TI	20	3/3/3	3	Sí/Sí/Sí	No (representado por STG)
A-18	SRV-C21-DB	Servidor, Ubuntu Server	Base de datos	Admin. de TI	20	3/3/3	3	Sí/Sí/Sí	No
A-19	SRV-C21-STG	Servidor, Ubuntu Server	Staging	Admin. de TI	20	3/3/2	3	Sí/Sí/Sí	Sí
A-20	SRV-C21-BKP	Servidor, Ubuntu Server	Respaldo con datos de clientes	Admin. de TI	20	3/3/2	3	Sí/Sí/Sí	No

Activos adicionales del SOC (no cuentan dentro de los 20): SRV-C21-SOC (VM de Wazuh, VLAN 90; nombre de laboratorio SRV-C21-WAZUH), consola Kaspersky propuesta en una VM SRV-C21-KSC dentro de VLAN 90 e instancia de GLPI en una nube hipotética.

> ***[CAPTURA FA-01 · FA_inventario_glpi.png]*** *Pega aquí el inventario en GLPI con los equipos reportados por el agente, para contrastarlo con esta tabla.*

Anexo B — Matriz de riesgos

Escalas: P e I de 1 a 5. Nivel = P × I: 1–4 Bajo · 5–9 Medio · 10–16 Alto · 17–25 Crítico.

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-01	Fuerza bruta SSH contra servidores expuestos	SRV-C21-DEMO, SRV-C21-STG	4	4	16 (Alto)	Regla 100100, active response y PB-01	SOC N1	2
R-02	Servidores de demostración sin parchear (CVE críticos)	SRV-C21-DEMO, SRV-C21-DB	4	5	20 (Crítico)	Detección de vulnerabilidades de Wazuh, PB-09 y gestión de cambios	Admin. de TI	2
R-03	Datos reales de clientes en entornos de prueba	SRV-C21-DEMO, STG, BKP	3	5	15 (Alto)	Política de enmascaramiento (artículo 12 de la base de conocimiento), FIM y revisión periódica	Responsable del SOC	6

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-04	Alteración no autorizada de la configuración del ERP	SRV-C21-DEMO, STG	3	4	12 (Alto)	FIM, regla 100101 y PB-03	SOC N1	2
R-05	Credenciales de la VPN de soporte comprometidas	NGFW / VPN	3	4	12 (Alto)	Logs del NGFW hacia Wazuh, reglas 100102 y 100103, PB-04 y MFA (trabajo futuro)	SOC N1 y Admin. de TI	5
R-06	Malware en estación o portátil Windows	PC-C21 y NB-C21	4	3	12 (Alto)	Kaspersky, control web y PB-02	SOC N1	3
R-07	Pérdida o robo de portátil de un consultor en el cliente	NB-C21 y MB-C21	3	4	12 (Alto)	Cifrado de disco, inventario en GLPI y procedimiento de reporte	Admin. de TI	4
R-08	Respaldos con datos de clientes sin cifrar o con acceso amplio	SRV-C21-BKP	2	5	10 (Alto)	Cifrado, acceso restringido, FIM y prueba de restauración	Admin. de TI	2
R-09	Phishing dirigido a consultores y gerencia	Usuarios	4	3	12 (Alto)	PB-06, control web y capacitación	SOC N1	6
R-10	Agente detenido o equipo sin cobertura (incluye macOS)	Todos los equipos	3	3	9 (Medio)	KPI de cobertura, alerta de agente desconectado e inventario de GLPI	SOC N1	2
R-11	Falta de segmentación entre oficina y servidores	VLAN 10 y VLAN 20	3	4	12 (Alto)	VLAN y reglas del NGFW	Líder del proyecto	1
R-12	Cuentas privilegiadas compartidas o sin MFA	Servidores, GLPI y consolas	3	4	12 (Alto)	PB-08, perfiles de GLPI y MFA	Responsable del SOC	4
R-13	Exposición de datos personales en los logs del SOC	SIEM y GLPI	2	3	6 (Medio)	Minimización, acceso por perfiles y retención de 90 días (Ley 1581)	Responsable del SOC	1

Anexo C — Plantilla de ticket de seguridad (GLPI)

La columna de ejemplo muestra cómo se diligencia el ticket T-01; reemplaza los datos marcados con los de tu laboratorio y repite el formato para T-02 a T-06.

Campo	Plantilla	Ejemplo T-01 (completar con datos reales)
Título	[Origen] [ID de alerta] – resumen corto	[Wazuh] [regla 100100] – Fuerza bruta SSH contra SRV-C21-STG
Categoría	Seguridad › subcategoría	Seguridad › Fuerza bruta

Campo	Plantilla	Ejemplo T-01 (completar con datos reales)
Origen de la solicitud	Wazuh / Kaspersky / NGFW / Usuario	Wazuh
Elemento asociado	Activo afectado del inventario	SRV-C21-STG (A-19)
Urgencia / impacto / prioridad		No ejecutado; supuesto hipotético / No ejecutado; supuesto hipotético / Media
Fecha y hora de la alerta (America/Bogota)		No ejecutado; supuesto hipotético
Activo y usuario afectados		SRV-C21-STG; usuario objetivo No ejecutado; supuesto hipotético
IP de origen / destino		No ejecutado; supuesto hipotético / IP de SRV-C21-STG
Qué ocurrió		No ejecutado; supuesto hipotético
Enriquecimiento (reputación, historial)		No ejecutado; supuesto hipotético
Evidencias (enlaces, capturas, hash)		No ejecutado; supuesto hipotético
Acciones realizadas por N1		No ejecutado; supuesto hipotético
Clasificación	Falso positivo / Benigno / Verdadero positivo	No ejecutado; supuesto hipotético
Decisión	Cerrar / Escalar a N2	No ejecutado; supuesto hipotético
Solución y cierre		No ejecutado; supuesto hipotético
Mejora propuesta (ajuste de regla, política)		No ejecutado; supuesto hipotético

Anexo D — Informe de incidente

Incidente seleccionado: T-01 — fuerza bruta SSH simulada contra SRV-C21-STG (ticket GLPI #1). Este informe es SIMULADO: las horas e IP son ilustrativas (IP de documentación 203.0.113.45) y no representan un incidente observado en Wazuh.

Sección	Contenido
1. Identificación	Incidente INC-C21-001; ticket GLPI #1; detección 20/10/2026 11:53; analista N1: Felipe Gómez (turno A); severidad final: Media; estado: contenido, pendiente de cierre

Sección	Contenido
2. Resumen ejecutivo	Se simuló un ataque de fuerza bruta por SSH contra el servidor de staging. La regla personalizada 100100 detectó más de 6 fallos en 60 segundos desde una misma IP y la respuesta activa bloqueó la dirección. No hubo acceso exitoso. Impacto nulo sobre datos de clientes.
3. Detección	Regla 100100 de Wazuh (basada en la regla 5760), nivel 10, MITRE T1110. Fuente: registro de autenticación del agente de SRV-C21-STG.
4. Línea de tiempo	Ver tabla siguiente
5. Activos y usuarios afectados	SRV-C21-STG (VLAN 20, staging). Cuenta objetivo: usuario de servicio ficticio «svc-staging». Sin cuentas comprometidas.
6. Análisis	Se consultó el historial de eventos del agente: ningún inicio de sesión exitoso desde la IP de origen. La reputación de la IP se consultó solo en fuentes públicas (sin subir archivos). Clasificación: verdadero positivo de baja gravedad por bloqueo efectivo.
7. Contención y respuesta	Bloqueo automático de la IP por active response durante 10 minutos y bloqueo permanente en el NGFW solicitado por ticket. Se verificó que la cuenta objetivo no tuvo accesos exitosos.
8. Impacto	Confidencialidad: sin impacto; integridad: sin impacto; disponibilidad: sin impacto; datos personales involucrados: ninguno (datos ficticios).
9. Recomendaciones	Mantener SSH solo con llave y desde la VLAN 99; añadir la IP al bloqueo del NGFW; revisar el umbral de la regla 100100 tras el piloto.
10. Lecciones aprendidas	La respuesta activa redujo el tiempo de contención; la creación manual del ticket añade minutos al tiempo de reconocimiento (mejora futura: integración Wazuh → GLPI).
11. Notificaciones	Responsable del SOC por correo; sin notificación a gerencia por severidad Media.
12. Anexos	Capturas, extractos de logs y evidencias (referenciar nombres de archivo del ZIP)

Línea de tiempo

Hora (America/Bogota)	Evento	Fuente
20/10/2026 11:52 (ilustrativo)	Inicio de los intentos fallidos de SSH	Registro de autenticación del agente
20/10/2026 11:53 (ilustrativo)	Alerta de la regla 100100	Wazuh
20/10/2026 11:53 (ilustrativo)	Bloqueo de la IP por active response	Wazuh / firewall del agente
20/10/2026 12:00 (ilustrativo)	Apertura del ticket y reconocimiento	GLPI
20/10/2026 12:20 (ilustrativo)	Triage completo y clasificación	GLPI
20/10/2026 12:35 (ilustrativo)	Decisión: cerrar tras verificar el bloqueo; sin escalamiento a N2	GLPI

Anexo E — Correo de solicitud de cotización y cuadro consolidado

Correo modelo (adaptado a C21; enviar desde una cuenta propia, identificándote como estudiante):

> ***Asunto:*** *Solicitud de cotización académica – firewall de nueva generación para una pyme (ejercicio universitario)*
>
> *Buenos días. Soy [nombre y apellido], estudiante de [programa] en [institución]. Como parte de un ejercicio académico, sin compromiso de compra, estoy diseñando un SOC para una empresa ficticia de 10 empleados y 20 equipos de cómputo. Agradezco su cotización de un firewall de nueva generación con estos requisitos: enlace de Internet de [velocidad] [con/sin doble proveedor]; 10 usuarios y 20 equipos; VPN de acceso remoto para [N] usuarios; un servicio expuesto (HTTPS) con publicación por NAT; 2 VLAN; funciones: prevención de intrusiones, control de aplicaciones, filtrado web, antimalware e inspección SSL/TLS; [alta disponibilidad sí/no]; exportación de logs por syslog. Por favor incluir: equipo (referencia), suscripciones de seguridad a 1 y 3 años, soporte y garantía, instalación y capacitación (si aplica), valores en COP con IVA discriminado, vigencia, tiempo de entrega y datos de contacto. Muchas gracias por su atención.*
>
> *[Nombre completo] · [Programa e institución] · [Correo y teléfono]*

Cuadro consolidado de cotizaciones (solo valores de las cotizaciones recibidas):

Concepto	Opción A	Opción B	Opción C
Marca y modelo	Palo Alto Networks PA-440 (modelo de referencia)	Fortinet FortiGate de gama de entrada (modelo por confirmar)	Ruijie RG-WALL (modelo por confirmar)

Concepto	Opción A	Opción B	Opción C
Proveedor y contacto	Distribuidor autorizado por identificar; no contactado	Distribuidor autorizado por identificar; no contactado	Distribuidor autorizado por identificar; no contactado
Fecha y vigencia de la cotización	Estimación académica; sin fecha ni vigencia comercial	Estimación académica; sin fecha ni vigencia comercial	Estimación académica; sin fecha ni vigencia comercial
Rendimiento con seguridad activa	Objetivo ≥300 Mbps; confirmar ficha técnica	Objetivo ≥300 Mbps; confirmar ficha técnica	Objetivo ≥300 Mbps; confirmar ficha técnica
Equipo (COP)	COP 9.500.000	COP 5.800.000	COP 4.200.000
Suscripciones año 1 (COP)	COP 3.000.000	COP 1.800.000	COP 1.200.000
Renovación años 2 y 3 (COP)	COP 3.000.000/año (estimado)	COP 1.800.000/año (estimado)	COP 1.200.000/año (estimado)
Soporte y garantía (COP)	Incluido en estimación; validar	Incluido en estimación; validar	Incluido en estimación; validar
Instalación y capacitación (COP)	COP 1.000.000 (estimado)	Incluido en COP 5.800.000	COP 600.000 (estimado)
IVA (COP)	IVA incluido como supuesto; no cotizado	IVA incluido como supuesto; no cotizado	IVA incluido como supuesto; no cotizado
Total inicial (COP)	COP 13.500.000 aprox. (equipo + año 1 + instalación)	COP 7.600.000 aprox. (equipo + año 1)	COP 6.000.000 aprox. (equipo + año 1 + instalación)
TCO a 3 años (COP)	COP 19.500.000 aprox. (3 años)	COP 11.200.000 aprox. (3 años)	COP 8.400.000 aprox. (3 años)
Tiempo de entrega	No cotizado; entrega por confirmar	No cotizado; entrega por confirmar	No cotizado; entrega por confirmar
Observaciones	Mayor costo; funciones por validar	Balance costo/capacidad; referencia del presupuesto recomendado	Menor costo estimado; soporte y rendimiento por validar

Anexo F — Playbooks del SOC N1 adaptados al caso C21

Cada playbook usa la plantilla del Anexo F de la guía, con los activos, herramientas y umbrales de ERP Pyme S.A.S. Se propone publicarlos como artículos 1 a 9 de la base de conocimiento de GLPI; dicha publicación no está verificada. Responsable: Analista SOC N1; aprobación prevista: Responsable del SOC; versión 1.0; fecha de revisión propuesta: 19/10/2026. No ejecutado; supuesto académico hipotético.

PB-01 — Fuerza bruta SSH / RDP

Campo	Contenido
Objetivo	Detectar y contener intentos masivos de autenticación contra SSH de los servidores (SRV-C21-DEMO, DB, STG, BKP) y RDP de estaciones Windows
Disparador y fuente	Wazuh: reglas de autenticación fallida (5760) y regla personalizada 100100 (6 o más fallos en 60 s desde una IP); registros del NGFW
Severidad inicial y criterios	Media. Sube a Alta si hubo un inicio de sesión exitoso posterior o si el objetivo es SRV-C21-DEMO (expuesto). Crítica si hay una cuenta privilegiada comprometida con acciones posteriores
Triage	1. ¿La IP de origen es interna o externa? Consultar reputación. 2. ¿Cuántos intentos, contra cuántos usuarios y en qué ventana? 3. ¿Hubo acceso exitoso con el mismo usuario o desde la misma IP? 4. ¿El servicio debe estar expuesto a Internet? 5. ¿Es una prueba autorizada o un usuario que olvidó su clave?
Contención permitida a N1	Verificar el bloqueo temporal por active response (600 s); bloquear la IP externa en el NGFW con aprobación del Responsable del SOC; solicitar a TI el bloqueo de la cuenta objetivo si no es privilegiada
Acciones que N1 no debe realizar	Reiniciar servicios, cambiar llaves SSH, modificar reglas del NGFW sin ticket de cambio, borrar registros, atacar de vuelta a la IP de origen
Evidencia a guardar	ID de alerta, número de intentos, IP, usuarios, captura del tablero y la regla de bloqueo aplicada
Criterio de escalamiento a N2	Acceso exitoso tras los fallos; objetivo es una cuenta privilegiada o un servidor crítico; el ataque proviene de una IP interna
Cierre y documentación en GLPI	Ticket categoría Seguridad › Fuerza bruta con clasificación, acciones y hora; vincular el activo afectado
Mejora continua	Restringir SSH a la VPN, exigir llaves y MFA; ajustar el umbral de la regla 100100 según el ruido
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-02 — Malware detectado por el EDR

Campo	Contenido
Objetivo	Atender detecciones de Kaspersky en estaciones y portátiles Windows (incluida la prueba EICAR del laboratorio)
Disparador y fuente	Kaspersky: detección de objeto malicioso; alerta en Wazuh con la regla 100200

Campo	Contenido
Severidad inicial y criterios	Media si fue bloqueado o desinfectado en un solo equipo. Alta si se ejecutó, persiste, afecta varios equipos o a un servidor. Crítica con comportamiento de ransomware o propagación
Triage	1. ¿Qué acción tomó el EDR (bloqueó, desinfectó, cuarentena o se ejecutó)? 2. Nombre de la amenaza, ruta, hash, proceso padre y usuario. 3. ¿Otros equipos tienen el mismo hash? 4. ¿Origen probable (correo, USB, web, descarga)? 5. Reputación del hash sin subir el archivo
Contención permitida a N1	Poner el archivo en cuarentena; aislar el equipo si se ejecutó o hay indicios de propagación; informar al usuario; no apagar el equipo salvo instrucción de N2
Acciones que N1 no debe realizar	Borrar evidencia, reinstalar el equipo, modificar políticas o exclusiones, subir archivos a servicios públicos
Evidencia a guardar	Captura del evento en la consola, hash, ruta y línea de tiempo de eventos del agente en Wazuh
Criterio de escalamiento a N2	Ejecución confirmada, comportamiento de ransomware, más de un equipo, el equipo es un servidor o el EDR no pudo remediar
Cierre y documentación en GLPI	Confirmar la limpieza con análisis completo; anotar causa probable; reforzar la capacitación del usuario
Mejora continua	Revisar control web y de dispositivos; ajustar acciones de la política
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-03 — Cambio en archivos críticos (FIM)

Campo	Contenido
Objetivo	Validar cambios en /etc/odoo/odoo.conf, /etc/ssh y /etc/sudoers.d de los servidores, y en carpetas vigiladas de Windows
Disparador y fuente	Wazuh: syscheck (archivo agregado, modificado o eliminado) y regla 100101
Severidad inicial y criterios	Baja o Media si existe un ticket de cambio aprobado. Alta si ocurre fuera de ventana o en un servidor de demostración o staging. Crítica con indicios de manipulación de binarios o de autenticación
Triage	1. ¿Existe un ticket de cambio aprobado en GLPI para esa ventana? 2. ¿Qué usuario o proceso hizo el cambio? 3. ¿Qué cambió (hash, permisos, contenido)? 4. ¿Coincide con una actualización o un despliegue? 5. ¿Es un ejecutable nuevo en un directorio sensible?
Contención permitida a N1	No modificar ni borrar el archivo; si hay indicios de compromiso, escalar y solicitar a N2 el aislamiento
Acciones que N1 no debe realizar	Revertir el cambio por cuenta propia, borrar el archivo, reiniciar el ERP
Evidencia a guardar	Datos de syscheck (hash antes y después, usuario, proceso), ticket de cambio y capturas
Criterio de escalamiento a N2	Sin ticket de cambio en un servidor; cambios en autenticación, sudoers o tareas programadas; sospecha de manipulación del ERP

Campo	Contenido
Cierre y documentación en GLPI	Si es legítimo, vincular al ticket de cambio y cerrar como benigno; ajustar la regla si genera ruido
Mejora continua	Exigir ticket de cambio para toda modificación de configuración; afinar rutas vigiladas
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-04 — Inicio de sesión fuera de horario o anómalo

Campo	Contenido
Objetivo	Validar accesos SSH o VPN fuera del horario laboral (lunes a viernes, 7:00–19:00) o desde ubicaciones no habituales
Disparador y fuente	Wazuh: reglas 100102 (fuera de horario) y 100103 (fin de semana); registros de VPN del NGFW
Severidad inicial y criterios	Media con usuario estándar. Alta si es una cuenta privilegiada o hay un viaje imposible. Crítica si va seguido de acciones sensibles
Triage	1. ¿El usuario tenía guardia o trabajo autorizado (calendario o ticket)? 2. ¿IP y ubicación habituales? 3. ¿Accesos desde ubicaciones lejanas en poco tiempo? 4. ¿Qué hizo tras el acceso? 5. Confirmar con el usuario por un canal alterno (llamada), sin enviar datos sensibles
Contención permitida a N1	Si no es legítimo: solicitar el cierre de sesiones y el restablecimiento de contraseña; solicitar a TI el bloqueo de la cuenta si no es privilegiada
Acciones que N1 no debe realizar	Deshabilitar o modificar cuentas privilegiadas por cuenta propia
Evidencia a guardar	Logs de sesión, IP, hora, ubicación aproximada y respuesta del usuario
Criterio de escalamiento a N2	Cuenta privilegiada, acciones sensibles posteriores, el usuario no reconoce el acceso o hay varias cuentas implicadas
Cierre y documentación en GLPI	Documentar la excepción autorizada; recomendar MFA o restricciones por horario y geografía
Mejora continua	Ajustar el horario de las reglas con los turnos reales; MFA en VPN
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-05 — Uso de USB no autorizado

Campo	Contenido
Objetivo	Atender conexiones de almacenamiento extraíble no permitidas en estaciones y portátiles
Disparador y fuente	Kaspersky: control de dispositivos (bloqueo) y evento enviado a Wazuh
Severidad inicial y criterios	Media si fue bloqueado y no hubo copia de datos. Alta si hubo copia de datos de clientes o ejecución desde el USB
Triage	1. ¿Equipo, usuario y tipo de dispositivo? 2. ¿Estaba en la lista blanca? 3. ¿Hubo lectura o escritura de archivos? 4. ¿Hay datos de clientes en el equipo? 5. Confirmar el motivo con el usuario
Contención permitida a N1	Mantener el bloqueo; solicitar al usuario que retire el dispositivo; aislar el equipo si hay indicios de malware

Campo	Contenido
Acciones que N1 no debe realizar	Revisar el contenido personal del dispositivo, modificar la lista blanca sin ticket de cambio
Evidencia a guardar	Evento de la consola, identificador del dispositivo, hora y usuario
Criterio de escalamiento a N2	Copia confirmada de datos de clientes, malware en el dispositivo o reincidencia
Cierre y documentación en GLPI	Registrar la decisión de lista blanca (si aplica) y la capacitación al usuario
Mejora continua	Revisar la lista blanca y ofrecer alternativas seguras de transferencia
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-06 — Phishing reportado

Campo	Contenido
Objetivo	Atender correos sospechosos reportados por consultores, desarrolladores o gerencia
Disparador y fuente	Reporte de un usuario por ticket en GLPI o por correo; alerta del EDR o del control web
Severidad inicial y criterios	Media si el usuario no interactuó. Alta si hizo clic, entregó credenciales o abrió un adjunto. Crítica si hay cuenta privilegiada comprometida
Triage	1. ¿El usuario hizo clic, abrió adjuntos o ingresó credenciales? 2. Remitente, asunto, URL y adjuntos (sin abrirlos fuera de un entorno controlado). 3. ¿Otros usuarios recibieron el mismo correo? 4. Reputación de la URL o del hash sin subir archivos confidenciales
Contención permitida a N1	Pedir al usuario que no interactúe más; solicitar a TI la eliminación del correo en los buzones afectados y el bloqueo del dominio; solicitar el restablecimiento de contraseña si hubo interacción
Acciones que N1 no debe realizar	Abrir adjuntos en el equipo del analista, responder al remitente, reenviar el correo malicioso a terceros
Evidencia a guardar	Correo en formato adjunto seguro, encabezados, URL y capturas del reporte
Criterio de escalamiento a N2	Credenciales entregadas, adjunto ejecutado, varios usuarios afectados o cuentas privilegiadas
Cierre y documentación en GLPI	Documentar la acción tomada y notificar a los usuarios afectados
Mejora continua	Capacitación de concientización y MFA
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-07 — Escaneo de puertos / reconocimiento

Campo	Contenido
Objetivo	Atender sondeos de puertos contra el servidor de demostración expuesto y el perímetro
Disparador y fuente	Registros del NGFW (IPS) y reglas de Wazuh sobre conexiones múltiples

Campo	Contenido
Severidad inicial y criterios	Baja si fue bloqueado en el perímetro. Media si el objetivo es SRV-C21-DEMO o hay sondeo repetido. Alta si es seguido de intentos de explotación
Triage	1. ¿IP de origen, reputación y puertos sondeados? 2. ¿Algún puerto abierto respondió? 3. ¿Hay intentos posteriores de autenticación o explotación? 4. ¿Es un escaneo autorizado del propio equipo?
Contención permitida a N1	Bloqueo temporal de la IP externa en el NGFW con aprobación; verificar que no haya puertos innecesarios expuestos
Acciones que N1 no debe realizar	Escanear de vuelta a la IP de origen, cerrar servicios productivos sin ticket de cambio
Evidencia a guardar	Registros del NGFW, IP, puertos y resultado de la verificación
Criterio de escalamiento a N2	Sondeo seguido de explotación o acceso, o provenir de una IP interna
Cierre y documentación en GLPI	Documentar el bloqueo y la revisión de exposición
Mejora continua	Reducir la superficie expuesta (publicar solo HTTPS) y ajustar el IPS
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-08 — Cuenta privilegiada nueva o elevación de privilegios

Campo	Contenido
Objetivo	Detectar cuentas administrativas creadas o añadidas a grupos privilegiados sin autorización (Linux: sudo y sudoers; Windows: administradores locales)
Disparador y fuente	Wazuh: eventos de creación de usuario, adición a grupos y cambios en sudoers (FIM sobre /etc/sudoers.d)
Severidad inicial y criterios	Alta. Crítica si la cuenta se usó para acceder o cambiar configuraciones. Baja o informativa si hay ticket de cambio aprobado
Triage	1. ¿Existe un ticket de cambio aprobado? 2. ¿Quién creó la cuenta y desde dónde? 3. ¿Se usó la cuenta? 4. ¿Hay otros cambios en el mismo periodo?
Contención permitida a N1	Informar al Administrador de TI y a N2; solicitar la verificación de la cuenta; no modificar la cuenta
Acciones que N1 no debe realizar	Eliminar o deshabilitar cuentas privilegiadas por cuenta propia
Evidencia a guardar	Evento original, usuario que ejecutó el cambio, hora y captura
Criterio de escalamiento a N2	Sin ticket de cambio (escalamiento inmediato), uso de la cuenta o cambios asociados
Cierre y documentación en GLPI	Vincular al ticket de cambio o registrar el incidente y su resolución por N2
Mejora continua	Exigir ticket de cambio para cuentas privilegiadas y revisar periódicamente los grupos de administración
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

PB-09 — Vulnerabilidad crítica

Campo	Contenido
Objetivo	Gestionar CVE críticos o altos detectados en los servidores de demostración, base de datos y librerías
Disparador y fuente	Wazuh: detección de vulnerabilidades con CVE críticos o altos en uno o más agentes
Severidad inicial y criterios	Media por defecto. Alta si es explotable, está expuesta a Internet (SRV-C21-DEMO) o hay explotación activa conocida. Baja si no aplica al entorno
Triage	1. ¿El software está instalado y en uso? 2. ¿El equipo está expuesto a Internet? 3. ¿Existe parche o mitigación? 4. ¿Hay indicios de explotación en los registros? 5. ¿Cuál es la criticidad del activo en el inventario?
Contención permitida a N1	Crear un ticket de gestión de vulnerabilidad con responsable y fecha límite; proponer una mitigación temporal (restringir acceso o desactivar el servicio) con aprobación; no instalar parches en producción sin ticket de cambio
Acciones que N1 no debe realizar	Instalar parches o reiniciar servidores por cuenta propia, desactivar servicios productivos sin aprobación
Evidencia a guardar	CVE, paquete y versión, activo afectado y resultado de la verificación
Criterio de escalamiento a N2	Explotación activa, activo crítico expuesto o sin parche disponible
Cierre y documentación en GLPI	Confirmar el parche con un nuevo análisis del agente y actualizar el inventario
Mejora continua	Definir ventanas de parcheo y metas por severidad; mantener cero CVE críticos abiertos por más de 30 días
Responsable, versión y fecha	Analista N1; v1.0; No ejecutado; supuesto hipotético

Anexo G — Lista de verificación de entrega

Elemento	Cumple
Fase 0. Carta de autorización, inventario (20 equipos) y matriz de riesgos	☐
Fase 1. Diagramas, VLAN, flujos con puertos, dimensionamiento y retención	☐
Fase 2. Wazuh instalado; agentes Windows y Linux; FIM; SCA; vulnerabilidades; 3 o más reglas/decoders; active response; dashboards; pruebas	☐
Fase 3. Kaspersky: edición justificada; consola; agentes; políticas; tareas; exclusiones; eventos en Wazuh; prueba EICAR	☐
Fase 4. GLPI en la nube con HTTPS; configuración completa; lista de verificación; respaldo y restauración	☐
Fase 5. Tres cotizaciones reales con fecha y contacto; matriz; justificación	☐
Fase 6. Manual del SOC; 9 playbooks; 6 o más tickets (3 reales); informe de incidente	☐
Fase 7. Presupuesto con fuentes; TCO; cronograma; RACI	☐
Fase 8. Informe en PDF; repositorio privado sin secretos; video de 12–15 min con alerta de principio a fin	☐
Declaración de uso de IA (Anexo I) adjunta	☐

Elemento	Cumple
Revisión final: sin contraseñas, tokens, llaves, IP públicas propias ni datos reales; permisos de acceso a enlaces verificados	☐
Nombres de archivo según el formato indicado (Parcial_SOC_N1_C21_[Apellido])	☐

Anexo H — Carta de autorización y reglas de compromiso

CARTA DE AUTORIZACIÓN Y REGLAS DE COMPROMISO — Implementación de un SOC Nivel 1 (laboratorio académico)

1. Partes. El Cliente: ERP Pyme S.A.S. (empresa ficticia), representada para efectos académicos por un representante ficticio. El Consultor académico: Brayan Javier Becerra Sandoval y Christian Julian Peña Mantilla. Este anexo es un modelo de autorización sin firmas reales ni efecto jurídico.
2. **Objeto.** Autorizar al Consultor a diseñar e implementar, en un entorno de laboratorio aislado, un SOC Nivel 1 para el Cliente, que incluye la instalación y configuración de un SIEM (Wazuh), un EDR/XDR (Kaspersky), un sistema de tickets e inventario (GLPI) y la cotización de un firewall de nueva generación.
3. Alcance. Activos incluidos en el diseño: máquinas virtuales del laboratorio (SRV-C21-WAZUH, PC-C21-WIN01, SRV-C21-STG, VM auxiliar Ubuntu), consola Kaspersky propuesta y una instancia hipotética de GLPI identificada como GLPI-C21. Activos excluidos: cualquier sistema de terceros, institucional o de producción real. la institución o de Internet.
4. **Actividades autorizadas.** Instalación y configuración de las herramientas en máquinas virtuales propias; generación de eventos de prueba controlados (archivo de prueba EICAR, modificación de archivos vigilados, intentos de inicio de sesión fallidos contra máquinas virtuales propias); consulta de fuentes públicas de reputación.
5. **Actividades prohibidas.** Escaneos, ataques o pruebas de credenciales contra sistemas no incluidos en el alcance; captura de tráfico ajeno; uso de datos personales reales; desactivación de controles de seguridad de equipos de terceros; divulgación de credenciales o evidencias sensibles.
6. Ventana académica de referencia: desde 19/10/2026 hasta 22/10/2026. No autoriza pruebas contra activos reales ni sustituye una autorización legal para una implementación futura.
7. **Confidencialidad y datos.** Los datos del ejercicio son ficticios. Las credenciales y evidencias se manejan como información restringida y no se publican.
8. Detención y contacto. Ante cualquier hallazgo real, duda sobre el alcance o impacto inesperado, el Consultor detiene la actividad y contacta al docente por el canal institucional de la asignatura; no se inventa ni publica una dirección de correo.
9. **Marco legal.** Las partes reconocen la Ley 1273 de 2009 y la Ley 1581 de 2012 y se comprometen a actuar dentro de sus límites.
10. **Firmas.** Cliente: _____ Consultor: _____
    Fecha: 22 / 10 / 2026

Anexo I — Declaración de uso de inteligencia artificial

Declaración de los autores: se usó IA (ChatGPT y Claude) como apoyo para estructurar y redactar el informe, según la tabla. La ejecución en el laboratorio y la verificación de las capturas fueron realizadas por los estudiantes.

Herramienta de IA	Para qué se usó	Qué se verificó o probó	Qué se modificó o rechazó
ChatGPT (OpenAI)	Estructurar y revisar la redacción del informe; apoyar la organización de las fases, la explicación de Wazuh y las tablas de CAPEX, OPEX, TCO, cronograma y matriz RACI.	Se revisó la coherencia interna del documento y se utilizaron las capturas proporcionadas como evidencia visual de la instalación y acceso al dashboard de Wazuh. Los costos se trataron como supuestos académicos.	Se ajustaron afirmaciones para distinguir la evidencia visual, el diseño propuesto y los escenarios hipotéticos.
Claude (Anthropic)	Estructurar el informe, redactar borradores de texto de diseño, tablas y plantillas de reglas y playbooks	Instalación de Kaspersky Endpoint Security en la VM WIN10-KASPERSKY-01 y vínculo con la consola en la nube; creación de las VM en VirtualBox; instalación de GLPI en laboratorio y registro de 6 tickets; revisión de las capturas contra el texto del informe. No se validaron reglas con wazuh-logtest ni la prueba EICAR.	Se ajustaron afirmaciones para distinguir la evidencia visual, el diseño propuesto y los escenarios hipotéticos.

Nombre: Brayan Javier Becerra Sandoval · Firma 

· Nombre: Christian Julian Peña Mantilla · Firma 

Fecha: 22 / 10 / 2026.